ISC2 CC Prep Course by Mike Chapple Notes

Written by Dev Balaji A

ISC2 Certified in Cybersecurity (CC) – Exam Overview

Exam Format

Type - Multiple-choice, computer-based test

Testing Center - Pearson VUE

Duration - 2 hours

Number of Questions - 100–125

Average Time per Question - ~1 minute

Answer Choices - 4 options per question

Correct Answers - 1 per question

Scoring & Passing

Scoring Scale - 0–1000 points

Passing Score - 700 / 1000

Focus is on knowledge recall and basic understanding, not deep technical analysis

---

Exam Domains & Weighting

Domain 1 - Security Principles (26%)Largest domain

Information assurance fundamentals

Risk management process

Types of security controls

Security governance

ISC2 Code of Ethics

Domain 2 - Business Continuity, Disaster Recovery & Incident Response (10%)

Smallest domain

Purpose and importance of -

Business Continuity (BC)

Disaster Recovery (DR)

Incident Response (IR)

Key components of BC, DR, and IR plans

Domain 3 - Access Control Concepts (22%)

Physical access controls

Logical access controls

How access is granted, enforced, and monitored

Domain 4 - Network Security (24%)

Basic computer networking concepts

Network threats and attacks

Network security infrastructure

Domain 5 - Security Operations (18%)

Data protection methods

System hardening

Security best practices and policies

Security awareness and training

Question Style & Difficulty

Straightforward multiple-choice questions

No trick questions

No deep technical or advanced cybersecurity scenarios

Based directly on -

Course material

Core cybersecurity fundamentals

Certification Level

Entry-level certification

Designed for -

Beginners

Career changers

Early IT / security professionals

Exam Tips (Very Important for CC)

Time management matters (~1 min/question)

Focus on definitions, purposes, and basic concepts

Memorize domain weightings (helps prioritize study)

Think “best answer”, not “most complex answer”

CC Exam – Adaptive Testing (Computerized Adaptive Testing / CAT)

What Is Adaptive Testing?

The CC exam uses computerized adaptive testing (CAT)

The exam adjusts question difficulty based on your performance -

Correct answers -> progressively harder questions

Incorrect answers -> easier questions

The testing software statistically evaluates your responses to determine whether you meet the passing standard

---

How the Exam Adapts

The exam is customized to your knowledge level

Question count -

Minimum - 100 questions

Maximum - 125 questions

The exam can end at any point after the 100th question

Once the algorithm determines pass or fail with confidence, the exam stops

---

Good News About Adaptive Testing

You may not need to answer all 125 questions

You only see questions that are necessary to evaluate your knowledge

The exam is not harder than the previous fixed-format exam

You are tested on the same content and domains

Limitations / Bad News

No skipping questions

No going back to review or change answers

Each question must be answered once and only once

Older exam strategies (multiple passes, reviewing answers) no longer apply

---

Exam Strategy Implications (Important for CC)

Read each question carefully before answering

Treat every question as final

Avoid rushing, even if questions feel easy or hard

Difficulty level is not an indicator of pass/fail

Information Security Careers - Essential Points Only

Information security is consistently ranked among the top jobs in the U.S.

Information Security Analyst ranked #1 best job in America (2022)

Job growth - ~33% through 2030 (much faster than average)

Pay - Median salary >$100,000

Entry-level role -

Typically Information Security Analyst

Starts as a generalist

Career progression -

Professionals often specialize later (e.g., network security, forensics, consulting)

Value of Information Security Certifications - Essential Points

Certifications show commitment to information security as a profession

Certifications help with job screening -

Often a minimum requirement

Needed to pass HR keyword filters

Certified professionals earn more than non-certified professionals

---

Salary Impact (High-Level Only)

Certified professionals earn significantly higher salaries on average than non-certified peers

Salary difference is substantial and well-documented in industry studies

---

Which ISC2 Certification to Choose (Exam-Relevant)

CC (Certified in Cybersecurity)

Entry-level certification

No experience required

Broad coverage of cybersecurity fundamentals

Ideal starting point

SSCP (Systems Security Certified Practitioner)

Mid-level certification

Requires 1 year of security experience

Broader, more hands-on security focus

CISSP (Certified Information Systems Security Professional)

Advanced / senior-level certification

Considered the gold standard

Often required for senior security roles (e.g., CISO)

Common progression after CC or SSCP

ISC2 Code of Ethics - Essential Exam Notes (High Importance)

Why This Matters for CC

Directly tested in Domain 1 (Security Principles)

You must know the intent of each canon

Exact wording not required, but meaning is critical

Overview

Information security professionals must act honorably, responsibly, and ethically

Many organizations have internal ethics codes

ISC2 Code of Ethics applies to all certified members

Built around four canons

The Four ISC2 Code of Ethics Canons

Canon 1 - Protect Society, Infrastructure, and the Common Good

Actions must -

Support the betterment of society

Maintain public trust in the profession

Using security skills for unethical or illegal activities violates this canon

Applies broadly to public safety and confidence

Canon 2 - Act Honorably, Honestly, Justly, Responsibly, and Legally

Must -

Obey the law

Be truthful

Avoid unethical behavior

Examples of violations -

Lying

Covering up mistakes

Acting irresponsibly or dishonorably

Canon 3 - Provide Diligent and Competent Service to Principals

“Principals” means -

Employers (employees)

Clients (consultants)

Requires -

Competence

Diligence

Fulfilling assigned duties

Failing to perform agreed responsibilities violates this canon

---

Canon 4 - Advance and Protect the Information Security Profession

Actions should strengthen, not harm, the profession

Common violations -

Assisting others improperly on exams

Violating ISC2 NDA

Providing false endorsement information

Reporting Ethics Violations (Exam-Relevant)

Members are required to report violations

Failure to report a known violation is itself a violation

Reports must be -

Written

Notarized

Submitted using ISC2's official form

Must include -

Accused individual's name

Description of the violation

Which canon(s) were breached

Proof of standing

Any supporting evidence

Standing to File a Complaint

Standing means the violation must harm you or your profession

Canons 1 & 2

Protect society and legality

Anyone has standing (general public included)

Canon 3

Concerns service to employers or clients

Only employers or clients have standing

Canon 4

Protects the profession

Other professionals have standing

Does not require being a security professional

Example - CPAs, healthcare professionals

Enforcement

ISC2 Ethics Committee -

Reviews the complaint

Allows the accused to respond

Collects evidence

Possible outcome -

Revocation of certification

Information Security Fundamentals - CIA Triad (Core Exam Topic)

Why Information Security Matters

Modern organizations rely heavily on information

Sensitive data includes -

Customer information

Employee data

Internal operations

Critical business details

IT professionals must work with -

Security teams

Other IT staff

Business leadership

Goal - protect organizational information

CIA Triad (Three Core Cybersecurity Objectives)

Confidentiality

Integrity

Availability

This model is known as the CIA Triad and is fundamental to the CC exam

---

Confidentiality (Primary Focus Here)

Definition

Ensures that only authorized individuals can access information and systems

Concerned with keeping information secret

This is where security professionals spend much of their time

---

Major Threats to Confidentiality

You must recognize these threats and their basic controls.

Snooping

Attacker physically observes information

Examples -

Papers left on desks

Information visible in public areas

Primary Control -

Clean desk policy

Secure sensitive documents when unattended

Dumpster Diving

Attacker searches trash or recycling for sensitive information

Targets discarded documents

Primary Control -

Shredding documents before disposal

Eavesdropping (Physical)

Attacker overhears spoken conversations

Common locations -

Hallways

Cafeterias

Public areas

Primary Control -

Restrict sensitive conversations to -

Private offices

Closed conference rooms

Wiretapping (Electronic Eavesdropping)

Attacker intercepts electronic communications

Occurs after gaining access to a network

Primary Control -

Encryption of data in transit

Encrypted data is unreadable if intercepted

Social Engineering

Attacker manipulates people psychologically

Common techniques -

Impersonating executives or IT staff

Phishing emails

Creating urgency or fear

Primary Control -

Security awareness training

Educating users to recognize attacks

Encouraging reporting of suspicious behavior

Integrity - CIA Triad (Core Exam Topic)

Definition

Integrity ensures that information is not altered without authorization

Protects against -

Intentional changes by attackers

Accidental changes caused by system or service disruptions

Preventing integrity failures is a core IT security responsibility

---

Integrity Attacks You Must Know for CC

There are four integrity attack types explicitly covered.

Unauthorized Modification of Information

Attacker gains access and changes data in violation of policy

Can be -

External (e.g., attacker alters financial records)

Internal (e.g., employee changes payroll data)

Primary Control -

Principle of Least Privilege

Users receive only the permissions required to do their job

Impersonation Attacks

Attacker pretends to be another person

Common targets -

Managers

Executives

IT staff

Often used to convince someone else to modify data

Closely related to social engineering

Primary Control -

Strong user education and awareness

Man-in-the-Middle (MITM) Attacks

Attacker positions themselves between a user and a system

Intercepts and relays communications

Can -

Monitor activity

Steal credentials (e.g., passwords)

Primary Control -

Encryption of communications

Example - TLS for web traffic

Availability - CIA Triad (Core Exam Topic)

Definition

Availability ensures that authorized users can access systems and information when needed

Protects against -

System disruptions

Loss of access to data or services

Third pillar of the CIA Triad

Availability Disruption Events You Must Know

There are five availability-related events covered for CC.

Denial-of-Service (DoS) Attacks

Attacker overwhelms a system with excessive traffic

Legitimate users cannot access the service

Primary Controls -

Firewalls to block illegitimate traffic

ISP-based filtering to stop attacks before they reach the network

---

Power Outages

Loss of electrical power due to -

High demand

Natural disasters

Infrastructure failures

Results in system downtime

Primary Controls -

Redundant power sources

Backup generators

Hardware Failures

Failure of -

Servers

Storage devices

Network equipment

Causes loss of system or data access

Primary Controls -

Hardware redundancy

Failover components

Equipment Destruction

Physical damage to systems

Can be -

Accidental

Intentional

Disaster-related (fire, hurricane)

Primary Controls -

Redundant systems

Backup or secondary data centers

Cloud-based recovery options

Service Outages

Loss of service due to -

Software bugs

System errors

Infrastructure failures

Prevents user access to applications or data

Primary Controls -

Resilient system design

Fault-tolerant architectures

Access Control Fundamentals - Core Exam Topic (High Importance)

Purpose of Access Control

Ensures only authorized individuals can access -

Information

Systems

Networks

Foundational concept for security operations and identity management

---

Access Control Process (Three Steps)

You must know all three steps and their order.

Identification

User claims an identity

No proof is provided at this stage

Claim may be false

Examples -

Physical - stating your name to a security guard

Electronic - entering a username

Authentication

User proves their identity

Confirms the identification claim

Examples -

Physical - showing a driver’s license

Electronic - entering a password

Other authentication methods exist (covered later)

Authorization

System determines what the user is allowed to do

Occurs after authentication

Examples -

Physical - checking appointment or access list

Electronic -

Access Control Lists (ACLs)

Permission assignments to users or groups

AAA Model (Very Important for CC)

Access control systems also include accounting.

Authentication – verify identity

Authorization – grant permissions

Accounting – track user activity

Accounting

Records and logs user actions

May include -

System activity

Access attempts

Web browsing history

Must comply with -

Applicable laws

Organizational privacy policies

Identity and Access Management (IAM) Considerations

Access control mechanisms must work across -

On-premises systems

Cloud environments

Modern IAM systems should support -

Hybrid environments

Centralized identity management

Password Policies and Controls - Essential Exam Notes

Purpose of Password Policies

Define how users create and maintain passwords

Aim to reduce the risk of password compromise

Implemented as technical controls

Key Password Controls You Must Know

Password Length

Sets the minimum number of characters

Best practice -

At least 8 characters

Longer passwords are harder to guess

Password Complexity

Requires different character types -

Uppercase letters

Lowercase letters

Numbers

Special characters

Increased complexity makes passwords harder to guess

Password Expiration

Forces periodic password changes (e.g., every 180 days)

Trend -

Many organizations no longer require regular expiration

Passwords are changed only if compromised

Password History

Prevents reuse of old passwords

System remembers previously used passwords

Reduces predictable password patterns

User-Initiated Password Changes

Users should be able to -

Change passwords easily

Change passwords immediately if compromise is suspected

Password selection should be private

Password Reset Processes (Security Risk)

Poorly designed reset processes can be exploited

Attackers may attempt unauthorized password resets

Reset mechanisms must be carefully secured

Password Reuse Risks

Reusing passwords across sites increases risk

If one site is compromised -

Attackers may test the same password elsewhere

Difficult to technically enforce, but important to discourage

---

Password Managers (Best Practice)

Secure password vaults

Store unique, strong passwords per site

Often protected by -

Biometrics

Automatically fill credentials

Reduce user burden while increasing security

Authentication Factors & MFA - Core Exam Topic

Authentication Overview

Authentication is how a user proves their identity

Systems use different authentication factors

CC focuses on three authentication factors

The Three Authentication Factors

Something You Know

Knowledge-based authentication

Examples -

Passwords

PINs

Security question answers

Most commonly used factor

Weakness -

Can be stolen (e.g., phishing)

Something You Are

Biometric authentication

Based on physical characteristics

Examples -

Fingerprints

Facial recognition

Iris scans

Voice recognition

Weakness -

Not perfect

Biometric data may be spoofed or misused

Something You Have

Requires possession of a physical device

Examples -

Smartphone authentication apps (software tokens)

Hardware token key fobs

Typically generate one-time passwords

Weakness -

Device can be lost or stolen

Multifactor Authentication (MFA)

Definition

Uses two or more different authentication factors

Increases security by combining factors

Valid MFA Examples

Password (something you know) + smart card (something you have)

PIN (something you know) + fingerprint (something you are)

NOT Multifactor Authentication (Common Exam Trap)

Password + security question

Both are something you know

This is not MFA

Why MFA Works

Compromising one factor is not enough

Attacker must defeat multiple, different factors

Single Sign-On (SSO)

Definition

Allows users to authenticate once and access multiple systems

Shares authenticated sessions across systems

How SSO Works

User logs in to the first SSO-enabled system

Authentication session is reused by other systems

Session expires after a defined time period

Often set to a full business day

Non-Repudiation - Essential Exam Notes

Definition

Repudiation - denying that an action occurred or that an agreement exists (denial of action)

Non-repudiation - security goal that prevents someone from falsely denying an action or transaction (proof against the denial of action)

Purpose of Non-Repudiation

Provides proof that -

An action was performed

A transaction occurred

An agreement was accepted

Commonly used in -

Legal disputes

Financial transactions

Security investigations

Common Non-Repudiation Controls

Physical Signatures

Signed contracts, receipts, agreements

Prove that a person accepted specific terms

Digital Signatures (Very Important)

Electronic equivalent of physical signatures

Use encryption to bind -

A person

To a specific electronic document

Widely used for electronic documents and transactions

Biometric Controls

Fingerprints

Facial recognition

Prove that a specific individual -

Was present

Performed an action

Video Surveillance

Records presence and activity

Supports claims that an action occurred

Privacy & Personal Information - Key Exam Notes

Why Privacy Matters (IT Perspective)

Concern for our own personal data

Responsibility to educate users on protecting their information

Duty to support privacy officials and compliance efforts

Types of Private Information

Personally Identifiable Information (PII)

Any data that can be linked to a specific individual

Examples - name, ID numbers, financial data, contact details

Protected Health Information (PHI)

Healthcare-related records

Regulated by HIPAA (Health Insurance Portability and Accountability Act)

Reasonable Expectation of Privacy (Core Concept)

Legal principle used to determine whether information must be protected

Depends on -

Context of disclosure

Whether a reasonable person would expect privacy

Expectation of Privacy by Scenario

Public Disclosure

Social media posts, public comments

No reasonable expectation of privacy

Limited Sharing

Email, instant messaging, file sharing with specific people

Moderate expectation of privacy

Risk exists if communication is not encrypted

Government or Regulated Services

Taxes, healthcare portals, insurance registration

High expectation of privacy

Laws typically require strict protection of data

Workplace Systems (Very Important for Exam)

Employer-owned computers and networks

No reasonable expectation of privacy

Employers are generally allowed to monitor usage

IT Professional Responsibilities

Clearly communicate privacy expectations to employees

Ensure proper handling of -

PII

PHI

Passwords

Company confidential data

Cybersecurity & Risk Management - Key Notes

Core Responsibility of Cybersecurity

The primary responsibility of a cybersecurity professional is risk management

This includes -

Identifying risks

Assessing risks

Managing / mitigating risks

Goal - protect information, systems, and organizational assets

---

Types of Risk

Internal Risk

Originates within the organization

Often caused by -

Poor processes

Insider threats

Lack of controls

Example -

Weak check-processing procedures enabling employee fraud

Mitigation -

Internal controls (e.g., two-person control, separation of duties)

External Risk

Threat comes from outside the organization

Organization cannot stop the attack attempt, only reduce impact

Example -

Ransomware attack

Mitigation -

Multifactor Authentication (MFA)

Security awareness training

Social engineering awareness campaigns

Multi-Party Risk

Risk shared across multiple organizations

Often related to third-party providers

Example -

Compromise of a SaaS provider affecting all customers

Key idea -

One breach -> many victims

Legacy System Risk

Risks from outdated or unsupported systems

Common problems -

No security patches

Compatibility issues

Mitigation -

Replace with modern systems OR

Apply compensating security controls carefully

Intellectual Property (IP) Risk

IP is often a core business asset

Risks include -

Theft

Destruction

Unauthorized modification

Impact -

Severe financial and reputational damage

Especially critical for information-based organizations

Software License Compliance Risk

Risk of violating software license agreements

Consequences -

Audits

Legal penalties

Heavy fines

Mitigation -

Use license monitoring / asset management software

Risk Assessment - Core Exam Notes (Very Important)

Why Risk Assessment Exists

Security resources (time, money, people) are limited

Risk assessment helps prioritize what to fix first

Goal - focus on risks with the highest likelihood and impact

Key Definitions (High-Value Exam Terms)

Threat

External force that can cause harm

Can be -

Natural (earthquakes, hurricanes)

Man-made (hackers, malware, terrorism)

Not controllable by the organization

Threat Vector (Exam Term)

Method used to carry out a threat

Examples -

Phishing

Malware

Social engineering

Physical intrusion

Vulnerability

Weakness in security controls

Examples -

Missing patches

Weak firewall rules

Misconfigurations

Controllable by the organization

Risk

Exists only when BOTH are present -

A threat

A corresponding vulnerability

No threat OR no vulnerability = no risk

Risk Ranking Factors

Likelihood

Probability the risk will occur

Depends on environment and history

Example -

Earthquakes - high likelihood in California, low in Wisconsin

---

Impact

Damage if the risk occurs

Can range from minimal to catastrophic

Example -

Earthquake vs light rainstorm

Risk Assessment Methods

Qualitative Risk Assessment

Subjective

Uses categories -

Low / Medium / High

Common for -

Initial assessments

Simpler environments

Quantitative Risk Assessment

Objective and numeric

Calculates financial impact

More complex

Not required to know calculations for CC exam

Risk Management / Risk Treatment - Core CC Notes

What Is Risk Management?

Process of deciding how to handle identified risks

Occurs after risk assessment

Goal - control risks in a way that fits business needs and resources

---

Four Risk Response Options (Very Important)

Risk Avoidance

Eliminate the risk entirely

Change business practices so the risk no longer exists

Example -

Move a data center out of a flood zone

Risk Transference

Shift financial impact to another party

Most common method - insurance

Key exam point -

Risk is not eliminated

Reputation damage cannot be transferred

Risk Mitigation

Reduce likelihood and/or impact

Most common cybersecurity approach

Example -

Flood barriers

Firewalls

Security controls

Risk Acceptance

Do nothing beyond acknowledging the risk

Used when -

Cost of controls > benefit

Must be a deliberate business decision

Risk Profile

The complete set of risks affecting an organization

Guides selection of risk management strategies

Risk Levels & Terminology (High Exam Value)

Inherent Risk

Risk level before any controls are applied

Residual Risk

Risk that remains after controls are implemented

Cannot be eliminated completely

Control Risk

New risks introduced by controls themselves

Example -

Firewall failure after installing a firewall

Risk Tolerance

Amount of risk an organization is willing to accept

Set by business leadership

Risk management goal -

residual risk + control risk ≤ risk tolerance

Security Controls - Core CC Notes

What Are Security Controls?

Safeguards used to address identified risks

Purpose -

Reduce likelihood

Reduce impact

Detect security events

Examples include technical tools, policies, and physical protections

---

Control Objectives & Defense in Depth

Control Objective

The goal a control is trying to achieve

Multiple controls may share the same objective

Defense in Depth (Very Important)

Use multiple overlapping controls

Ensures protection if one control fails

Key exam idea -

Redundancy improves security

Controls by Purpose (Know These Three)

Preventive Controls

Stop incidents before they occur

Examples -

Firewalls

System hardening

Access controls

Detective Controls

Identify incidents after they occur

Require investigation

Examples -

Intrusion Detection Systems (IDS)

Antivirus scans

Security monitoring

Recovery (Corrective) Controls

Restore systems/data after an incident

Examples -

Backups

Disaster recovery procedures

Ransomware Example (Exam-Friendly)

System hardening -> Preventive

Antivirus scans -> Detective

Backups -> Recovery

Controls by Mechanism (Very Important)

Technical Controls (Logical Controls)

Use technology

Logical = Technical (same meaning on exam)

Examples -

Firewalls

Encryption

IDS/IPS

Antivirus

Data Loss Prevention (DLP)

Administrative Controls

Policies, procedures, and people-based processes

Examples -

Access reviews

Log reviews

Background checks

Security awareness training

Physical Controls

Protect facilities and hardware

Examples -

Locks

Security guards

Cameras

Badge systems

Laws, Regulations & Jurisdiction - Key Points

Why This Matters

Sensitive data is governed by laws and regulations

Compliance affects an organization’s risk posture

First step - determine which laws and regulations apply

Jurisdiction Complexity (Exam Concept)

Jurisdiction depends on multiple factors, not just company location -

Organization’s physical location

Customer location

Cloud provider location

Data center location

Multiple jurisdictions can apply at the same time

Key Jurisdiction Examples

Local / State / National laws

Company location -> local + national laws apply

Customer location may introduce additional state laws

Cloud computing complicates jurisdiction

Data stored or processed in other states or regions

International data laws

GDPR applies to personal data of EU residents, regardless of where the organization is located

---

Regulatory Sources

Laws

National, state, and regional government regulations

Example -

GDPR (European Union)

Non-Government Regulations

Industry standards

Example -

PCI DSS

Applies to credit card data worldwide

Enforced by banks, not governments

Security Policy Framework - Key Points

Security documentation is organized into four types -

Policies

Standards

Guidelines

Procedures

Policies

Foundation of the information security program

Define high-level security expectations

Mandatory compliance

Approved by senior leadership

Written to stand the test of time

Avoid specific technologies or locations

Good policy example

“Sensitive information must be encrypted at rest and in transit using approved technologies”

Bad policy example

“Use AES-256 encryption”

“Store records in room 225”

Standards

Provide specific, detailed requirements

Derive authority from policies

Include -

Approved encryption algorithms

Configuration settings

Storage locations

Mandatory compliance

Change more frequently than policies

Guidelines

Provide advice and best practices

Offer recommended, not required actions

Allow flexibility based on circumstances

Not mandatory

Example

“Employees should use encrypted Wi-Fi when available”

Procedures

Step-by-step instructions for specific tasks

Explain how to perform an activity

Examples -

Incident response activation

Account provisioning

Compliance may be -

Mandatory or

Optional (depends on organization and procedure)

High-Yield Exam Rules to Remember

Policies -> Mandatory

Standards -> Mandatory

Guidelines -> Optional

Procedures -> Depends

Common Security Policies - Key Points

Most organizations maintain a core set of security policies. You should recognize their purpose, not memorize long wording.

Acceptable Use Policy (AUP)

Defines what users are allowed and not allowed to do with company technology

Common topics -

Personal use of systems (allowed or limited)

Prohibition on unauthorized access

Consequences for violations

Applies to all users

Data Handling Policy

Defines what information is sensitive

Describes how sensitive data must be protected

Covers -

Digital data

Paper records

Focus - classification and protection of data

Password Policy

Documents all password requirements, such as -

Minimum length

Complexity

Expiration rules

Central reference for password controls

Bring Your Own Device (BYOD) Policy

Applies when employees use personal devices for work

Defines -

Security controls required on personal devices

Types of data allowed on those devices

Addresses risk from unmanaged hardware

Privacy Policy

Explains -

What personal data is collected

How it is stored, processed, transmitted, and protected

Applies to -

Employees

Customers

Other individuals

Often -

Publicly posted

Enforced by laws and regulators

Change Management Policy

Governs how technology changes are made

Requires -

Documentation

Approval

Controlled implementation

Must include rollback plans

Key indicator of a mature IT environment

Business Continuity Planning (BCP) - Key Points

What BCP Is

Business Continuity Planning (BCP) keeps the business running during disruptions

Also called -

Continuity of Operations Planning (COOP)

Supports the security objective of Availability (CIA triad)

Types of Disruptions Covered

Small-scale incidents

Single system failure

Large-scale disasters

Earthquakes, hurricanes, tornadoes

Scope Definition (Very Important)

Before building a plan, define -

What business activities are covered

What systems are covered

What controls will be considered

Purpose -

Prevent being overwhelmed

Enable prioritization

Business Impact Assessment (BIA)

Core tool used in BCP

A risk assessment (qualitative or quantitative)

BIA Process

Identify mission-essential business functions

Map them to critical IT systems

Identify risks to those systems

Assess likelihood and impact

BIA Output

Prioritized list of risks

Ranked by expected loss

Using BIA Results

Focus first on highest-impact risks

Control selection must consider cost vs benefit

Example logic -

If a control costs less than the expected loss it prevents -> worth implementing

---

Cloud and BCP

BCP is shared responsibility -

Cloud provider -

Physical protections (e.g., flood control)

Customer -

Replication across -

Data centers

Availability zones

Geographic regions

Availability Controls - Redundancy

Redundancy ensures a system continues operating after a single component failure

Goal - avoid outages caused by single points of failure (SPOFs)

Supports Business Continuity / Availability

Single Point of Failure (SPOF)

A single point of failure is any component whose failure causes the entire system to stop

SPOFs undermine business continuity

Single Point of Failure Analysis

A structured process to -

Identify SPOFs

Remove or mitigate them using redundancy

Continues until -

No new SPOFs are found, or

Cost outweighs benefit

Common SPOF Examples & Fixes

Web Server

Problem - One server fails -> service unavailable

Control -

Server clustering

Multiple servers provide the same service

If one fails, others continue

Firewall

Problem - Firewall failure blocks all access

Control -

High availability (HA) firewall pair

Primary + standby device

Network Connections

Problem - Single network link failure stops communication

Control -

Redundant network links

Traffic continues if one link fails

Cost Consideration

SPOF mitigation is not infinite

Stop adding redundancy when -

Cost exceeds expected benefit

Ties back to Business Impact Assessment (BIA)

Other Business Continuity Risks (Beyond SPOFs)

Vendor bankruptcy

Insufficient compute or storage capacity

Utility outages (power, internet)

Any operational risk that could disrupt services

Personnel Succession Planning

Often overlooked but critical

IT relies on key skilled personnel

Key Actions

Identify essential personnel

Identify successors for critical roles

Provide training and development in advance

Purpose -

Maintain continuity when employees leave

Reduce operational disruption

Availability - Core Technical Concepts

High Availability (HA)

Uses multiple systems to continue service after a failure

Focus - system keeps running even if one component fails

Examples -

Web server clusters

Primary + backup firewall

Often includes geographic dispersion (different sites)

Key idea - Redundancy at the system level

Fault Tolerance (FT)

Protects a single system from failing in the first place

System continues operating despite internal component failure

Focus - resilience within one system

Key idea - Prevent failure, not just recover from it

HA vs FT (Exam Favorite)

HA - Multiple systems continue service after failure

FT - One system survives component failure

Both support availability

Can be used together

Load Balancing (Clarification)

Distributes workload across multiple systems

Goal - scalability and performance

Not the same as HA, but often implemented together

Possible to have HA without load balancing and vice versa

Common Fault Tolerance Controls

Power

Power supplies are common failure points

Controls -

Dual power supplies

Each connected to separate power sources

UPS for short-term outages

Generators for long-term outages

PDUs provide clean, conditioned power

Storage - RAID

RAID = Fault tolerance, not backup

Protects against single disk failure only

RAID 1 – Mirroring

Two disks with identical data

If one disk fails, the other continues

Simple and reliable

RAID 5 – Striping with Parity

Three or more disks

Data + parity spread across disks

Can rebuild data if one disk fails

Exam warning - RAID does NOT replace backups

Networking Redundancy

Network failures can stop operations

Controls include -

Multiple ISPs

Dual network paths

NIC teaming (multiple NICs in one system)

Redundant network devices

Multipathing for server–storage connections

Diversity as an Availability Strategy

Avoid identical components failing simultaneously

Use -

Different vendors

Different technologies

Diverse cryptographic controls

Reduces systemic risk

Incident Response (IR) - The Big Picture

No organization is 100% secure.
Incident Response exists to handle security incidents calmly, consistently, and effectively when prevention fails.

The industry-standard model comes from NIST SP 800-61

This is the reference framework you should remember.

Why Incident Response Planning Matters

Incidents are chaotic and stressful

People make bad decisions under pressure

Organizations that handle incidents well -

Planned in advance

Documented their process

Organizations that fail -

“We’ll figure it out when it happens”

No structure -> confusion, delays, mistakes

Exam mindset -

Planning before an incident = better decisions during an incident

---

Incident Response Plan (IRP)

Every organization should have a formal Incident Response Plan that defines -

Policies

Procedures

Guidelines

This plan provides structure during a crisis.

Core Elements of an Incident Response Plan

Purpose & Scope

Why the plan exists

What incidents it covers -

Only cybersecurity incidents?

Any loss of sensitive data?

Clearly defines boundaries

Strategies & Goals

What are the top priorities?

Containment?

Recovery?

Evidence preservation?

These priorities must be decided in advance

Avoids confusion during response

Roles, Responsibilities & Authority

Who handles incidents?

Who makes decisions?

What authority do responders have?

Prevents delays and internal conflict

Communication

Internal team communication

Communication with -

Management

Other departments

Third parties

Poor communication = failed response

Senior Management Approval

Critical for enforcement

Gives responders authority

Helps when actions are unpopular (e.g., disconnecting systems)

Exam tip -
Senior management approval strengthens incident response authority.

Using Existing Templates

Refer to NIST SP 800-61 for guidance

Review plans from -

Universities

Government agencies

Large organizations

Templates help-but must be customized

Key idea -
Don’t reinvent the wheel, but don’t copy blindly either.

Incident Response Team (IRT) - Key Points

Purpose & Availability

Incident Response Team must be available 24/7

Have primary and backup members (vacations, long incidents)

Incident handling helps -

Keep skills sharp

Professional development

Who Should Be on the Team

You don’t activate everyone every time, but they must be identified and trained in advance -

Management

Information Security team

Technical experts

System engineers

Developers

DBAs

Virtualization experts

Legal counsel

Public affairs / Marketing

Human Resources

Physical security

-> Building relationships before incidents is critical.

Training & Preparation

Don’t wait for an incident

Team should -

Review the Incident Response Plan

Participate in regular training

Practice through testing and exercises

Goal - fast, coordinated response

External Incident Response Providers

Some organizations lack -

Forensics skills

Specialized IR capabilities

Solution -

Pre-contract an external IR provider

Never negotiate contracts during an incident

Incident Response Communications - Key Points

Purpose

Communications plan is a critical part of the Incident Response Plan

Supports stakeholder management

Ensures -

Right people are notified

At the right time

With the right information

Internal Communications

Incident notification and escalation procedures must be defined

Prevents confusion and delayed response

Limits unnecessary disclosure

External Communications (High Risk Area)

Communication outside the organization is sensitive

Unapproved disclosure can -

Trigger media attention prematurely

Damage reputation

Alert attackers and compromise the investigation

Public/media communication should be handled only by authorized teams (e.g., PR)

Law Enforcement Involvement

Usually not mandatory

Decision is complex because -

Incident details may become public

Evidence handling requirements are stricter

Always involve law enforcement if -

There is a threat to safety

A law or regulation requires reporting

Legal & Regulatory Requirements

Legal team must guide -

Reporting obligations

Notification timelines

Common obligations include -

Notifying individuals after personal data breaches

Reporting to regulators, agencies, customers, or the public

Requirements vary by -

Jurisdiction

Type of data

Impact of the incident

Secure Communication Channels

Plan must define how communication occurs

Secure communication mechanisms must be -

Established before incidents

Used to share sensitive details

Prevents leaks to -

The public

Attackers

Incident Detection & Monitoring - Key Points

Continuous Monitoring

After planning and team prep, incident response enters perpetual monitoring

Goal - detect incidents as they occur or shortly after

Requires a robust security monitoring infrastructure

Security Data Sources (Know These)

Organizations must collect, analyze, and retain security data from many sources, including -

IDS / IPS

Firewalls

Authentication systems

System & file integrity monitoring

Vulnerability scanners

System event logs

NetFlow / network connection records

Anti-malware tools

IT systems generate massive volumes of logs

SIEM (Security Information and Event Management)

Centralized log collection and analysis

Correlates data from multiple sources

Uses rules and algorithms to detect suspicious activity

Alerts security teams for investigation

Provides a single source of truth during incident investigations

Exam tip - SIEM exists to make log analysis possible at scale

---

External Incident Discovery

Sometimes monitoring fails, and incidents are discovered through -

Employees

Customers

External organizations

Examples -

Customer sees stolen data online

Compromised system attacks another organization

Employee can’t access email

Organizations must have a formal process to -

Receive reports

Record them

Evaluate credibility and severity

First Responder Responsibilities (Very Exam-Important)

First person who detects the incident = first responder

Their actions can determine success or failure

Highest Priority -

Contain the damage

Isolate affected systems

Prevent -

Further compromise

Lateral movement

Data exfiltration

Common action -

Quarantine systems

Remove from network

Keep powered on if needed to preserve evidence

Block communication with attackers

Exam favorite -

Containment comes before evidence collection

One-Line Exam Memory Hook

Detect -> Correlate (SIEM) -> Report -> Isolate

Disaster Recovery (DR) - Key Points

Business Continuity vs Disaster Recovery

Business Continuity (BC) - keeps the business running during disruption

Disaster Recovery (DR) - restores the business back to normal after BC fails

DR is a subset of business continuity

When Disaster Recovery Is Activated

When continuity controls fail or are overwhelmed

Disasters may be -

Natural (hurricane, earthquake)

Man-made (ransomware)

Internal (data center failure)

External (power outage)

Initial Disaster Recovery Response

Recognize the disaster quickly

Activate the DR plan

Focus on -

Containing damage

Restoring any immediate capacity

Possible actions -

Activate alternate processing sites

Contain physical damage

Engage emergency contractors

Organizational Shift During DR

Normal operations pause

Employees may take temporary roles

Flexibility is essential

DR roles should be -

Planned in advance

Supported with training

Communication During Disaster Recovery

Must be secure and reliable

Includes -

Initial activation communications (even after hours)

Ongoing status updates

Tactical, Ad Hoc communication

Critical for coordination and leadership awareness

Damage Assessment & Permanent Recovery

After immediate danger passes -

Assess damage

Triage systems

Move from temporary fixes -> permanent restoration

DR is not complete until -

Organization is back to normal operations in the primary environment

---

Disaster Recovery Metrics (Very Important)

Metric	Meaning
RTO (Recovery Time Objective)	Maximum acceptable time to restore a service
RPO (Recovery Point Objective)	Maximum acceptable data loss (time)
RSL (Recovery Service Level)	Minimum percentage of service availability during disaster

Example - Website may operate at 50% capacity during recovery

---

Training & Awareness

DR personnel must receive -

Periodic role-based training

Regular awareness refreshers

Ensures readiness during real disasters

Backups - Core Concepts

Why Backups Matter

Most critical DR control

Protect against -

Technology failure

Human error

Natural disasters

Malicious deletion or modification

Total data loss = business disaster

Backup Storage Options

Tape backups

Traditional, still common

Harder to manage

Disk-to-disk backups

Faster recovery

Often stored in separate facilities

SAN / NAS (Storage Area Networks / Networks Attached Storage) backups

Centralized network storage

Cloud backups

Geographic diversity

Cloud providers add extra protection via their own redundancy

---

Backup Types (Very Important for Exams)

Full Backup

Copies all data

Largest size

Longest backup time

Simplest restore

Snapshot

Special type of full backup

Uses platform features (e.g., virtualization)

Fast to create

Often used for short-term recovery

Differential Backup

Copies all changes since last full backup

Grows larger each day

Restore requires -

Last full backup

Most recent differential only

Incremental Backup

Copies changes since last full OR incremental backup

Smallest backup size

Restore requires -

Last full backup

All incremental backups since then (in order)

Differential vs Incremental - Exam Comparison

Feature	Differential	Incremental
Backup size	Medium	Small
Restore time	Faster	Slower
Restore complexity	Simple	Complex
Storage usage	More	Less

Disaster Recovery Sites - Most Important Points (Exam-Focused)

Disaster Recovery Sites are alternate facilities used when the primary data center is unavailable.

Usually idle and activated only during disasters.

Types of Disaster Recovery Sites

Hot Site

Fully operational data center

Systems and data are ready to run

Can activate immediately or automatically

Fastest recovery

Most expensive (similar cost to primary site)

Warm Site

Has hardware and software

Not fully up to date or actively running

Activation takes hours to days

Moderate cost

Balance between cost and recovery speed

Cold Site

Basic facility only (power, cooling, cabling)

No servers or data

Activation takes weeks or months

Least expensive

Slowest recovery

Quick Exam Comparison

Site Type	Cost	Recovery Speed	Equipment/Data
Hot	High	Immediate	Fully ready
Warm	Medium	Hours–Days	Partial
Cold	Low	Weeks–Months	None

Offsite Backups & Site Resiliency Concepts

DR sites often store offsite backups

Geographic separation reduces risk of one disaster affecting both sites

Site resiliency = selecting locations based on risk assessment

Backup Transfer Methods

Physical transport (tapes, disks)

Digital replication (SAN, VM replication)

Backup Availability

Online backups - fast restore, higher cost

Offline backups - slower restore, cheaper

Alternate Business Processes

Organizations may use manual or paper-based processes

Helps continue operations when IT systems are unavailable

Disaster Recovery Testing - Key Points

Purpose

Tests ensure the DR plan functions correctly

Helps identify updates needed due to technology or business process changes

---

Types of DR Tests

Read-Through (Checklist Review)

Staff review the current plan individually

Simple, theoretical exercise

Provides feedback on needed updates

Walk-Through (Tabletop Exercise)

Team meets to review and discuss the plan together

Still theoretical, but more effective than read-throughs

Helps clarify roles and responsibilities

Simulation

Team responds to a specific disaster scenario

Discusses how they would react, without activating real systems

Tests decision-making and planning

Parallel Test

DR environment is activated in parallel with primary systems

Operations continue at primary site

Tests technology and processes together

Full Interruption Test

Primary site is shut down

DR site takes over operations

Most effective test, but high risk and disruptive

Rarely performed

Physical Access Security of Facilities

Access Control

Limit physical access to facilities

Authenticate employees and track contractors/visitors

Prevent unauthorized access that could lead to theft, damage, or disruption

Critical Facilities

Data Centers - Contain servers, storage, and computing resources; require strict access control

Server Rooms - May lack strong controls and can proliferate in business units; need monitoring

Media Storage Facilities - Store critical backups; must be as secure as or more than main data centers

Evidence Storage Rooms - Used during forensic investigations; maintain chain of custody to prevent tampering

Wiring Closets & Cable Runs - Vulnerable to intrusion and network eavesdropping; must be secured

Other Restricted Areas - Operation centers and sensitive workspaces require protection

Security Assessments

Conduct an inventory of all sensitive locations

Perform regular physical security assessments

Ensure that security measures match the sensitivity and risk of the facility

---

Physical Security Program Design

Facility Placement and Deterrence

Physical security impacts both IT and the physical environment

Facilities located in high pedestrian or vehicle traffic areas reduce intrusion risk

Warning signs indicating monitoring and secured areas help deter potential attackers

Access Control

Gates and controlled access points focus security attention on entry areas

Security guards, alarm systems, and CCTV enhance monitoring and response capabilities

Bollards prevent unauthorized vehicle access; some are retractable for authorized vehicles

Crime Prevention Through Environmental Design (CPTED)

CPTED is a strategy to design facilities to naturally deter crime

Natural Surveillance

Design facilities so employees and passersby can observe the surroundings

Techniques include strategic window placement, open areas around fences, and adequate lighting

Natural Access Control

Use gates and structures to funnel people to monitored entry points

Limits an intruder’s ability to reach unsupervised areas

Natural Territorial Reinforcement

Clearly indicate restricted areas through signage, landscaping, and lighting

CPTED strategies reduce the risk of successful intrusions and enhance overall physical security

---

Visitor Access Control

Authorization and Approval

Procedures must define who can authorize visitor access

Clearly outline acceptable reasons for visits

Specify levels of approval based on visitor type and circumstances

Escorting and Supervision

Identify which visitors may have unescorted access

Define who may escort visitors when required

Logging and Identification

Maintain a visitor log (paper or electronic) for every entry

All individuals must wear identification badges

Visitor badges should be distinctive for quick recognition

Badges should indicate if escort is required

Monitoring

Cameras may be used to monitor visitor areas

Visitors must be informed about surveillance

Footage can be reviewed if suspicious activity occurs

Human Security in Physical Security Programs

Role of Security Personnel

Guards are crucial for evaluating visitor requests and granting access using human judgment

Technology assists, but cannot fully replace human discretion

Security personnel can present a welcoming face while maintaining security

In some environments, uniformed guards project authority and deter intrusions

Guards may be armed depending on local laws

Emerging Technology

Robot sentries can patrol facilities and monitor for abnormal activity

Robots may challenge intruders directly or summon human guards when needed

Two-Person Rule

Ensures sensitive operations are handled appropriately

Two-Person Integrity

Requires two people to access a sensitive area

Prevents theft or unauthorized activity by a single individual

Example - Accessing areas where valuable items are stored

Two-Person Control

Requires two individuals to authorize critical actions

Ensures no single person can execute highly sensitive operations alone

Example - Two-key system to launch a nuclear missile

Keys are separated so concurrence of both individuals is necessary

---

Account Management Responsibilities

Job Rotation

Employees are moved periodically between different jobs

Provides diverse experience and exposure to various operations

Enhances security by reducing fraud risk

Work is reviewed by others during rotations, deterring illegitimate activity

Mandatory Vacation Policies

Staff in key positions must take minimum consecutive vacation days annually

Employees lose access to corporate systems during vacation

Absence allows detection of potential fraudulent activity

Encourages disconnection from work, benefiting both security and personnel well-being

Standard Account Naming Conventions

Provides consistent identification of users and ties accounts to real identities

Example convention - first initial + up to 8 characters of last name

Duplicate accounts resolved by appending a unique number

Example - mchapple or mchapple2

Account and Credential Lifecycle Management

Provisioning - Assign new users the correct entitlements for their role

Modifying roles - Update entitlements when roles change

Reviewing access - Regular re-certification to remove unnecessary access

Revoking access - Terminate access for employees leaving the organization

Ensures proper access control and reduces risk of unauthorized activity

Provisioning -> Modify Roles -> Modify Permissions -> Account Reviews -> Termination of access

---

Account Monitoring and Permissions

Inaccurate Permissions

Incorrect or excessive permissions can -

Prevent users from performing their job

Violate the principle of least privilege

Privilege creep occurs when users gain new permissions for a new role but old permissions are not removed

Mitigation strategies -

Conduct regular user account audits with managers

Review all permissions for each user to ensure appropriateness

Pay attention to users who changed roles since the last review

Use formal attestation processes to verify managerial approval of access

Unauthorized Use of Permissions

Unauthorized use can occur -

By someone other than the legitimate user

By the legitimate user performing illegitimate actions

Detection requires continuous account monitoring systems

Examples of suspicious activity -

Impossible travel time logins – simultaneous logins from geographically distant locations

Logins from unusual networks – e.g., a user appears on a guest network instead of their normal office network

Unusual login times – e.g., accessing systems in the middle of the night

Deviations in behavior – accessing files not normally used or bulk downloading sensitive data

Advanced Monitoring Techniques

Geotagging – record geographic location for each login

Geofencing – define geographic boundaries and alert administrators when devices leave them

Helps in behavior-based monitoring and detecting anomalous activity

---

Account Provisioning and Deprovisioning

User Onboarding and Account Provisioning

When a new user joins, administrators -

Ensure they complete the onboarding process

Provision a user account with authentication credentials

Assign authorizations based on the user's job function

User Offboarding and Account Deprovisioning

When a user leaves, administrators -

Follow the offboarding process

Deprovision the account by removing credentials and permissions

Timely action is critical to prevent access to sensitive information

Particularly important in adverse terminations

Workflows for Account Termination

Planned departures -

Supervisor notifies HR

Account set to automatically expire on the user's last day

Emergency terminations -

Coordination between IT and HR to precisely time access revocation

Risks if mistimed -

Terminated too early - employee may anticipate termination and retaliate

Terminated too late - employee may access systems after being fired

Account Management in Windows Active Directory

Disabling accounts -

Temporarily suspends the account

Icon shows down arrow when disabled

Can be re-enabled if needed

Good practice to disable first before permanent deletion

Deleting accounts -

Permanent removal of user account

Ensures no further access to systems

Scheduling account expiration -

Example - for retirements, accounts can expire on a specific date via Account Properties

---

Authorization and Access Control

Overview of Authorization

Authorization is the final step in access control

Determines what resources and information an authenticated user can access

Works after authentication is successful

Principle of Least Privilege

Users should have only the minimum permissions needed for their job duties

Benefits -

Limits damage from insider attacks

- Restricts access if an external attacker compromises an account

Example - An accountant cannot modify website content because it’s outside their role

Approaches to Authorization

Mandatory Access Control (MAC)

Highly stringent and rule-based

Operating system enforces permissions based on labels for users and resources

Users cannot modify permissions themselves

Typically used in high-security environments

Discretionary Access Control (DAC)

Users have discretion to assign permissions for files and resources they own

Most common form of access control

Provides flexibility for daily operations

Example - File owners grant access to other users as needed

Role-Based Access Control (RBAC)

Simplifies management of authorizations

Permissions are assigned to roles, not individual users

Users are assigned to roles according to their job function

Advantages -

Easier onboarding - new users automatically receive permissions via roles

Easier updates - changes to a role automatically propagate to all users in that role

Design Considerations

Balance security requirements and business needs

Avoid being too lax, which jeopardizes security

Avoid being too strict, which hinders workflow and productivity

Choose an approach that fits the organization’s operational environment

---

Networking Fundamentals

Purpose of Networks

Connect computers to share resources and communicate

Enable activities such as -

Sending emails

Streaming video

Printing to shared printers

Accessing servers and other devices

Local and Wide Area Networks

Local Area Network (LAN) - connects devices in the same building

Wide Area Network (WAN) - connects multiple LANs, offices, or sites

LANs connected to WANs allow access to the internet and global communications

Wired Network Connections

Use Ethernet cables to connect devices to network ports

RJ-45 connectors - standard for Ethernet, 8 pins/wires

RJ-11 connectors - smaller, used for traditional telephones, 6 pins

Wired networks provide high speed and reliability but require physical cables

Wireless Network Connections

Wi-Fi - creates wireless LANs for smartphones, laptops, and other devices

Provides convenience without physical cabling

Personal and Short-Range Wireless Networks

Bluetooth - forms Personal Area Networks (PANs)

Connects peripherals to computers or smartphones

Typical range - ~30 feet / 10 meters

Near Field Communication (NFC) - extremely short range (~a few inches)

Used for wireless payments and building access systems

Bluetooth and NFC are not general-purpose networks but are useful for specific short-range applications

---

Networking Protocols and Models

TCP/IP Overview

TCP/IP - Transmission Control Protocol / Internet Protocol

Core protocols for modern networks and the internet

IP (Internet Protocol) -

Routes information across networks

Provides IP addresses to uniquely identify devices

Delivers data in chunks called packets

Operates at the network layer

Transport layer protocols - TCP and UDP

Transmission Control Protocol (TCP)

Connection-oriented protocol - establishes a connection before sending data

Reliable - guarantees delivery via acknowledgements from the receiving system

Used for applications requiring guaranteed delivery - email, web traffic

Three-way handshake process -

SYN - initiator requests a connection

SYN-ACK - destination acknowledges and requests reciprocal connection

ACK - initiator acknowledges, connection established

User Datagram Protocol (UDP)

Connectionless - sends data without establishing a connection

No acknowledgements, so delivery is not guaranteed

Used for voice, video, and streaming, where missing packets are acceptable

OSI Model (7 Layers)

Physical - transmits bits over wires, radio, fiber, etc.

Data Link - transfers data between nodes on the same network

Network - routes data across multiple nodes (IP works here)

Transport - ensures reliable communication (TCP/UDP)

Session - manages communication sessions between systems

Presentation - translates data, handles encryption/decryption

Application - interface for users, e.g., browsers and client applications

TCP/IP Model (Simplified Layers)

Combines OSI layers for practical implementation -

Network Interface Layer - OSI Physical + Data Link layers

Internet Layer - OSI Network layer

Transport Layer - TCP/UDP

Application Layer - OSI Session + Presentation + Application layers

---

Internet Protocol Addressing

For data to travel between systems the Internet Protocol needs an addressing scheme similar to phone numbers or postal addresses

These addresses are called IP addresses and they uniquely identify systems on a network

IPv4 addresses

IPv4 uses what is called dotted quad notation meaning four numbers are used, so 4 dotted notations (no unit) x 8 bits = 32 bits of size

Each number ranges from 0 to 255

This limit exists because each number is stored in eight binary bits which allows 2^8 = 256

An IPv4 address uniquely identifies a system on a network

Public IP addresses must be globally unique

Private networks such as homes and offices can reuse private IP addresses

Routers and firewalls translate private addresses to public ones using Network Address Translation also called NAT

Network and host portions

An IP address has two logical parts

The network portion identifies the network

The host portion identifies the specific system on that network

The dividing line between network and host can change

Subnetting allows networks to be divided into smaller segments

Source and destination addresses

Every communication uses two IP addresses

The source address shows where the data comes from

The destination address shows where the data is going

As systems communicate these roles swap depending on who sends each packet

IPv6 addresses

IPv4 address space is running out

IPv6 was created to solve this problem

IPv6 uses 8 colonized notation x 16 bit = 128 bits instead of 32 bits

This allows a massive number of unique addresses

IPv6 addresses are written in hexadecimal using eight groups

IP address assignment methods

Static addressing means manually configuring an IP address

Administrators must ensure the address is unique and valid

DHCP stands for Dynamic Host Configuration Protocol

DHCP automatically assigns IP addresses from a defined pool

Servers usually use static IP addresses

End user devices usually use dynamic IP addresses

Network Ports and Their Purpose

Network ports identify specific applications or services running on a system
IP address identifies the system
Port number directs traffic to the correct service on that system

---

Port Number Size and Range

Ports use 16 bits

Total possible ports = 2^16 = 65536

Port range is 0 to 65535

Port Categories

Well Known Ports 0–1023

Reserved for common and standardized services
Everyone knows where to find these services

HTTP Hypertext Transfer Protocol -> port 80

HTTPS Hypertext Transfer Protocol Secure -> port 443

FTP File Transfer Protocol -> port 21

SSH Secure Shell -> port 22

SMTP Simple Mail Transfer Protocol -> port 25

DNS Domain Name System -> port 53

Registered Ports 1024–49151

Assigned to specific vendors or applications

Microsoft SQL Server Structured Query Language Server -> port 1433

Oracle Database Listener -> port 1521

Dynamic Ports 49152–65535

Used temporarily by applications
Often chosen automatically by the operating system

Important Ports to Memorize for Exams

File and Remote Access

FTP File Transfer Protocol -> port 21

SSH Secure Shell -> port 22

RDP Remote Desktop Protocol -> port 3389

Windows Networking

NetBIOS Network Basic Input Output System -> ports 137, 138, 139

Email Services

SMTP Simple Mail Transfer Protocol -> port 25

POP3 Post Office Protocol ver. 3 -> port 110

IMAP Internet Message Access Protocol -> port 143

Web Services

HTTP Hypertext Transfer Protocol -> port 80

HTTPS Hypertext Transfer Protocol Secure -> port 443

Wireless Network Security

Protect wireless traffic from eavesdropping

Prevent unauthorized network access

Wireless Network Identification

SSID = Service Set Identifier

SSID is the visible WiFi network name

By default, SSID is broadcast

SSID broadcasting announces network availability

SSID broadcasting can be disabled

Hidden networks require users to know the SSID

Wireless Access Point Security

Access points have administrative accounts

Default admin passwords are often publicly known

Default passwords must be changed immediately

Strong passwords should be used

Admin access should be limited to authorized personnel

Types of Wireless Networks

Open Networks

No authentication required

Anyone can connect

Common in public locations

Very low security

Preshared Key Authentication

Common in home and small office networks

Uses a shared encryption key

Users enter a WiFi password to connect

Limitations

Changing the key requires reconfiguring all devices

No individual user identification

Access cannot be revoked for a single user

Not suitable for large organizations

Enterprise Wireless Authentication

Uses a centralized authentication server

Users authenticate with individual credentials

Supports username and password authentication

Allows user-specific access control

Easy to revoke access when a user leaves

Captive Portals

Used on unencrypted wireless networks

Common in hotels, airports, coffee shops

Redirects users to a login web page

Authentication methods

Accepting terms of service

Username and password

Payment or voucher

Wireless Encryption

Wireless encryption protects traffic from eavesdropping

Encryption hides data from anyone without the decryption key

Radio waves are inherently insecure

Encryption makes wireless communication secure

WEP – Wired Equivalent Privacy

Original wireless encryption standard

Designed to secure early WiFi networks

Has severe security vulnerabilities

Easily broken by attackers

Considered completely insecure

Must never be used on modern networks

WPA – Wi-Fi Protected Access

Introduced in 2003 as a replacement for WEP

Added security improvements to WEP

TKIP – Temporal Key Integrity Protocol

Changes encryption key for each packet

Prevents long-term key reuse attacks

Issues

WPA vulnerabilities discovered over time

No longer considered secure

Poor choice for modern networks

WPA2 – Wi-Fi Protected Access 2

Released in 2004

Major redesign instead of patching WEP

Uses AES – Advanced Encryption Standard

CCMP – Counter Mode Cipher Block Chaining Message Authentication Code Protocol

Strong encryption protocol

Based on AES

Widely used today

Security Status

Some weaknesses identified

Still considered secure

Commonly deployed in real-world networks

WPA3 – Wi-Fi Protected Access 3

Mandatory support for new devices starting 2020

Uses CCMP like WPA2

SAE – Simultaneous Authentication of Equals

Secure key exchange mechanism

Based on Diffie-Hellman - cryptographic method for two parties to establish a shared secret key over an insecure channel

Protects against offline password attacks

Improves initial connection security

Encryption Standards Summary

Unencrypted networks are highly vulnerable

WEP is equivalent to no encryption

WPA is insecure

WPA2 is secure and widely used

WPA3 is the most secure and recommended standard

Ping

Purpose

Checks if a remote system is reachable

Verifies basic network connectivity

Protocol Used

ICMP - Internet Control Message Protocol

How It Works

Sends ICMP Echo Request

Target replies with ICMP Echo Reply

Successful reply confirms connectivity

Troubleshooting Use

Ping target website

Reply -> network path works issue likely with service

No reply -> possible network issue

Ping another internet system

Reply -> internet works issue likely with target

Ping local network system

Reply -> local network works issue likely ISP

No reply-> local network or device issue

Test from another computer to isolate problem

Something more to know about Ping

Shows round trip time in milliseconds

Can ping IP address or domain name

Some systems block ICMP at firewall

No reply does not always mean system is down

Hping

Advanced variant of ping

Allows custom packet creation

Can test system presence on network

Older tool no longer actively developed

May be included in security focused OS distributions

Installation may be manual

Traceroute / Tracert

Purpose

Traces path packets take between two systems

Shows each hop along the route

Output Meaning

Each line represents one hop

IP addresses or domain names shown

Stars indicate devices that do not respond to ICMP

OS Differences

Mac and Linux -> traceroute

Windows -> tracert

Pathping Windows Only

Combines ping and tracert functionalities

Provides path and packet loss information

Malware Basics

Malware = malicious software

Designed to harm systems or data

Common goals include

Stealing information

Damaging or encrypting data

Disrupting normal system use

Core Components of Malware

Propagation Mechanism

How malware spreads from one system to another

Differs based on malware type

Payload

Malicious action performed after infection

Examples include

Stealing credit card or tax data

Encrypting data for ransom

Keylogging to capture usernames and passwords

Types of Malware

Virus

Requires user action to spread

Examples of user actions

Opening malicious email attachments

Clicking infected links

Inserting infected USB drives

Does not spread automatically

Best defense

User awareness and training

Worm

Spreads automatically without user interaction

Exploits software or OS vulnerabilities

Uses infected systems to spread further

Can move across LANs and the internet

Best defense

Regular patching and system updates

Trojan Horse

Disguised as legitimate or useful software

User willingly installs the program

Performs expected function

Also executes a hidden malicious payload

Best defense

Application control

Allow only approved software and versions

Quick Comparison for Exams

Virus -> needs user action

Worm -> self spreading

Trojan horse -> looks legitimate but is malicious

Botnets and Their Role in Cyber Attacks

What a Botnet Is

Botnet -> a collection of infected systems called bots or zombie computers

Bots are controlled remotely by a hacker known as the botnet operator

Primary goal -> steal computing power storage or network connectivity

How Systems Join a Botnet

Hacker infects a system using malware such as viruses worms or Trojans

Once infected the system is enrolled into the botnet

The infected system remains dormant until it receives instructions

Infection may continue spreading to other systems increasing botnet size

Why Hackers Build Botnets

Botnets provide large scale resources without owning hardware

Botnet operators often sell or rent access to others

Common Uses of Botnets

Sending massive volumes of spam

Distributed Denial of Service attacks DDoS

Cryptocurrency mining using stolen CPU and GPU power

Brute force password attacks

Any attack requiring large scale processing or bandwidth

Command and Control (C2) Networks

Botnet operators must communicate with bots to issue commands

Direct communication is avoided to prevent easy detection

Indirect and hidden communication methods are used

Common Command and Control Mechanisms

Internet Relay Chat IRC channels

Social media platforms such as Twitter

Peer to peer communication between bots

Multiple redundant channels to survive takedowns

Why C2 Infrastructure Is Redundant

Security teams actively shut down known C2 servers

Multiple channels ensure continued control

Control lasts as long as at least 1 C2 path remains active

Botnet Lifecycle Summary

Malware infects systems worldwide

Infected systems become bots

Bots connect to a command and control network

Botnet receives and executes commands

Botnet may continue expanding through further infections

Security Relevance

Botnets are a major source of large scale cyber attacks

Understanding botnet behavior helps identify infections

Monitoring unusual outbound connections can reveal botnet activity

---

Eavesdropping and Interception Attacks

Eavesdropping Basics

Occurs when an attacker gains physical or logical access to a network

Attacker listens to communications between a client and a server

Especially dangerous if encrypted traffic is decrypted without user knowledge

Requires compromise of the communication path, such as
-> Tapping network cables or devices
-> Compromising network equipment
-> Using DNS poisoning or ARP poisoning to redirect traffic

Web Communication Path

Web traffic does not travel directly from client to server

It passes through many intermediate devices

Any intermediate device can become an eavesdropping point

Encryption like HTTPS prevents intermediaries from reading or modifying data

Man in the Middle Attack (MITM)

Attacker tricks the client into connecting to the attacker instead of the real server

Often uses DNS poisoning or ARP poisoning

Attacker connects to the real server on behalf of the user

User authenticates to the fake server without realizing it

Attacker can
-> Read all traffic
-> Modify responses
-> Relay traffic transparently

User remains unaware of interception

Man in the Browser Attack

Variation of MITM

Attacker compromises the web browser or browser plugins

Allows direct access to web traffic inside the browser

Can bypass some network-based protections

Replay Attack

Attacker captures previously transmitted data

Commonly targets authentication tokens

Attacker reuses captured data to authenticate later

Attacker usually cannot see actual credentials

Relies on reuse of encoded authentication data

Replay Attack Prevention

Session tokens
-> Randomly generated
-> Valid only for a short time

Timestamps
-> Systems verify messages were sent in a valid time window
-> Expired or old messages are rejected

SSL Stripping Attack

Attacker forces browser to downgrade from HTTPS to HTTP

Variation of Eavesdropping attack

Removes encryption protection

Exposes traffic to easy eavesdropping

User may believe the connection is still secure

Cryptographic Implementation Flaws

Overview

Cryptographic systems may have flaws in design or implementation

Flaws create vulnerabilities that attackers can exploit to undermine security

Fault Injection Attacks

Attacker deliberately causes a fault in the cryptographic device

Methods include -
-> Applying high voltage or unusual currents
-> Extreme temperatures (high or low)
-> Other environmental manipulations

Potential consequences -
-> Device fails to encrypt data properly
-> Unencrypted data is exposed
-> Other cryptographic failures

Side-Channel Attacks

Exploit physical characteristics of a system rather than weaknesses in the algorithm

Collect system activity footprints such as -
-> Processor usage patterns
-> Power consumption
-> Electromagnetic radiation

Can reveal information being encrypted if the cryptography is poorly implemented

Timing Attacks

A type of side-channel attack

Measures how long cryptographic operations take

Information from timing can help attacker infer secret keys or plaintext

Relies on minute differences in operation duration to extract secrets

---

Intrusion Detection and Prevention Systems (IDS/IPS)

Overview

IDS and IPS are key defensive tools for network security

Monitor traffic for malicious activity and respond appropriately

---

Intrusion Detection Systems (IDS)

Purpose - Monitor network traffic and alert administrators of potential threats and suspicious activities

Examples of detected threats -
-> SQL injection attempts to a web server
-> Malformed packets attempting DoS attacks
-> Unusual login patterns based on time or history
-> Internal systems contacting Botnet command and control (C2) servers

Limitations - Administrators may be overwhelmed by alerts or unavailable to respond immediately

---

Intrusion Prevention Systems (IPS)

Difference from IDS - Can take immediate action to block threats

Often deployed inline to stop malicious traffic before it reaches its destination

---

Errored Alerts in IDS/IPS

True Positive (TP)
-> Scanner correctly identifies a vulnerability or attack that actually exists.
-> Example - Nessus detects a medium-strength SSL cipher that really is on the server.

True Negative (TN)
-> Scanner correctly identifies that there is no vulnerability or attack.
-> Example - Nessus scans a port and confirms no outdated SSL certificate exists, and that’s true.

False Positive (FP)
-> Scanner reports a vulnerability or attack that does not actually exist.
-> Example - Nessus flags an SSL configuration as weak, but it’s actually compliant.

False Negative (FN)
-> Scanner fails to detect a vulnerability or attack that actually exists.
-> Example - Nessus misses an outdated SSL protocol running on the server.

Why This Matters

True Positives -> Actionable, you can fix the real issues

True Negatives -> Confidence that parts of the system are secure

False Positives -> Wastes time investigating non-issues, can lead to alert fatigue

False Negatives -> Dangerous, leaves vulnerabilities unaddressed, can be exploited by attackers

---

Detection Technologies

Signature Detection (Rule-Based Detection)

Works like antivirus software

Uses databases of known attack patterns (signatures)

Pros - Low false positive rate, reliable

Cons - Cannot detect new or unknown attacks

Anomaly Detection (Behavioral/Heuristic Detection)

Builds a model of normal network activity

Flags deviations as suspicious
-> Example - VPN connection from unusual geographic location or time

Pros - Can detect new attack types

Cons - High false positive rate

Alternate names - Behavior detection, Heuristic detection

IDS Deployment Methods

Network-Based IDS (NIDS)

Monitors traffic across a network segment

Usually connected to a SPAN/mirror port on a switch

Can detect attacks from any system on the network

Passive - does not block traffic, only alerts

Host-Based IDS (HIDS)

Installed on a specific system

Monitors system logs, file integrity, and local processes

Can detect attacks like unauthorized file changes or privilege escalation

Inline IDS (uncommon)

Sometimes placed directly in the network path

Can drop malicious packets if configured, but this is more typical of IPS

IPS Deployment Methods

In-Band (Inline) Deployment

IPS sits directly in the network path

Can block traffic immediately

Risk - IPS failure can disrupt all network traffic (single point of failure)

Out-of-Band (Passive) Deployment

IPS sits outside the traffic flow

Monitors traffic through span/mirror port on a switch

Cannot block initial attacks but can issue commands for future prevention

Also called passive mode

Malware Protection Tools

Types of Malware Covered

Viruses

Worms

Trojan horses

Spyware

Antivirus Software Mechanisms

a. Signature Detection

Uses databases of known malware patterns

Scans system files and memory for matches

If a match is found -
-> Removes the malicious content or
-> Quarantines it for further analysis

Important - Virus definition files must be frequently updated

b. Heuristic / Behavior Detection

Models normal system activity

Detects anomalies that deviate from the norm

Found in advanced malware protection tools like EDR (Endpoint Detection and Response)

EDR Capabilities

Performs deep endpoint monitoring -
-> Memory and processor usage
-> Registry entries
-> Network communications
-> Other system behaviors

Offers real-time protection

Can trigger automated responses to stop malware

Supports sandboxing -
-> Suspicious executables are tested in a controlled environment

-> If malicious behavior is detected, it is blocked from executing

Example - Windows Defender

Included with Windows OS

Main screen shows scan status

Scan types - Quick, Full, Custom

Update tab - checks latest virus definitions

History tab - shows quarantined items and scan history

Vulnerability Assessment Tools

Importance of Vulnerability Testing

Security testing helps identify weaknesses before attackers do

Discovering and fixing issues early is safer than responding to an active exploit

Manual testing is tedious, so automation is essential

Categories of Vulnerability Assessment Tools

Port scanners

Vulnerability scanners

Application scanners

Port Scanners

Probe systems for open network ports

Comparable to checking every door to see which ones are unlocked

Scan all 65,535 TCP ports

Help identify exposed services that could be attacked

Nmap (Network Mapper)

Most popular port scanning tool

Runs from the command line

Requires permission to scan target systems

How Nmap Works

Command format -
-> nmap "IP Address"

Scans target system for open ports

Scan duration depends on -
-> Number of ports scanned
-> Network distance between systems

Example Scan Results

Port 80 -> HTTP (Web Server)

Port 3389 -> RDP (Remote Desktop Protocol)

Port 3389 strongly indicates a Windows system

Port 80 confirms a web service is running

Security Implications

Open ports reveal active services

Attackers use this information to target vulnerabilities

Security professionals use results to -
-> Verify required services
-> Disable unnecessary ports
-> Harden exposed services

Vulnerability Scanners

What They Do

Go deeper than port scanners

Examine which services are running on open ports

Check servers against a database of known vulnerabilities

Produce reports with remediation information
-> Useful for fixing systems
-> Dangerous in the hands of attackers

Popular Tool - Nessus

Web-based vulnerability scanning tool

Can scan a server for a wide range of vulnerabilities

Interface allows detailed configuration and results viewing

Nessus Scan Process

Scan duration varies - typically 10–15 minutes per server

Depends on -
-> Number of plug-ins
-> Server configuration
-> Network bandwidth

Example Scan Results

Found 4 medium vulnerabilities

Found 20 informational vulnerabilities

Medium vulnerabilities often require immediate attention

Example vulnerabilities detected -
-> SSL certificate can't be trusted
-> Supports medium-strength cipher suites
-> Self-signed SSL certificate

Using Nessus Effectively

Reports provide -
-> Detected issues
-> Details on vulnerabilities
-> Steps to remediate problems

Helps improve system security by following remediation guidance

---

Data Center Environmental Controls

Temperature

Electronic equipment generates significant heat -> excessive heat reduces lifespan

Cooling is critical -> massive cooling systems are used in data centers

Recommended range - 64.4°F -> 80.6°F (expanded environmental envelope, ASHRAE standards)

Humidity

Too high -> condensation -> water damage to electronics

Too low -> static electricity -> equipment damage

Recommended dew point - 41.9°F -> 50°F

HVAC Systems

Heating, ventilation, and air conditioning maintain stable temperature and humidity

Controls ensure electronic equipment operates within safe ranges

Fire Protection

Fires need 3 elements - heat, oxygen, fuel -> removing one element extinguishes fire

Water-based suppression removes heat but can damage equipment

Wet pipe systems - pipes filled with water at all times -> high risk if pipe bursts

Dry pipe systems - water held back until fire detection -> lowers risk of flooding

Chemical suppression - removes oxygen to fight fire -> must be used carefully in occupied areas

Other Environmental Threats

Flooding, electromagnetic interference, and other physical threats must also be mitigated

Agreements and Standards

Internal data center -> responsible for own environmental protections

Shared organizational data center -> outline requirements in a Memorandum of Understanding (MOU)

Outsourced data center services -> specify environmental conditions in Service Level Agreement (SLA)

Network Security Zones and Firewalls

Network Border Firewall

Connects three security zones with three interfaces

Interface 1 - connects to internet or untrusted network -> allows outbound connections from trusted networks -> blocks most inbound connections except those allowed by security policy

Interface 2 - connects to organization's intranet -> internal network where most systems reside -> may be subdivided into endpoint, wireless, guest, data center, and other subnet segments -> firewall or additional firewalls control access between segments

Interface 3 - connects to DMZ (demilitarized zone) -> hosts systems that accept external connections such as web and mail servers -> isolates high-risk systems from intranet

Network Trust Models

Traditional approach -> implicit trust based on network zone

Modern approach -> zero trust -> systems do not gain privileges solely based on network location

Special Purpose Networks

Extranet - intranet segment accessible by external parties -> e.g., vendors connect via VPN to limited intranet resources

Honeynet (Honeypot Networks) - decoy network designed to attract attackers -> contains no sensitive info -> used to study attacker behavior and protect legitimate systems

Ad Hoc networks - temporary wired or wireless networks outside standard security design -> may present risk if connected to intranet without proper security -> can expose sensitive information or provide entry for attackers

Network Traffic Directions

East-West traffic - between systems within a data center

North-South traffic - between data center systems and external internet systems

Firewalls may regulate both types of traffic when crossing security zones

---

Network Devices and Their Roles

Switches

Connect devices to networks

Contain multiple network ports -> small switches may have 8 or fewer ports -> large switches may have 500 or more ports -> typical example is a 48 port switch

Usually hidden in wiring closets or secure locations

Each port connects to a network cable -> cables run through conduits and terminate at wall face plates -> allows easy connection/disconnection without damaging cables

Connect wired devices directly

Work at Layer 2 of OSI model -> use MAC addresses only

Some switches also work at Layer 3 -> interpret IP addresses -> start taking on router functions

Wireless Access Points (APs)

Provide network access without wires

Contain radios to send and receive signals to mobile devices

AP connects back to switch via wired connection -> allows wireless devices to reach the network

Routers

Connect multiple networks together

Act as central aggregation point for network traffic

Decide best path for traffic to reach destination

Perform security filtering using Access Control Lists (ACLs) -> limit traffic based on organization's policy -> this type is stateless inspection -> does not track connection state

Firewalls extend this capability with stateful inspection

Virtual LANs (VLANs)

Purpose

VLANs logically group related systems -> location on physical network doesn’t matter

Allows separation of users by department or function -> e.g., accounting separate from sales or IT

Extends broadcast domain -> users on the same VLAN can communicate as if on the same switch

Works at Layer 2 of OSI model -> does not involve routers or firewalls

Configuration

Enable VLAN trunking -> allows switches in different locations to carry the same VLANs

Configure switch ports -> assign each port to appropriate VLAN

Switching technology handles creation of logical VLANs -> connects related users and enforces separation

Security Use

Network segmentation -> reduces risk by limiting communication between unrelated systems

Micro segmentation -> extreme, small network segments -> can be temporary -> created to allow communication and removed when no longer needed

Firewalls

Purpose

Act as security guards of a network -> analyze connection attempts -> allow or deny based on security policy

Sit at network perimeter -> between routers and internet -> monitor inbound and outbound traffic

Internal traffic may flow freely -> anything crossing perimeter must be evaluated

Common Network Placement

Connect three networks -> internet -> internal network -> DMZ

DMZ contains systems that must accept outside connections -> e.g., public web servers

DMZ isolates higher-risk systems -> compromise in DMZ does not give access to internal network

Inspection Techniques

Stateless inspection -> evaluates each packet separately -> inefficient -> no context

Stateful inspection -> tracks established connections -> evaluates new requests against firewall rules only

Firewall Rules

Rules define traffic handling -> key characteristics -
-> Source system
-> Destination system
-> Destination port and protocol
-> Action -> Allow or Deny

Example -> web server in DMZ with IP 10.15.100.1
-> Source - Any
-> Destination - 10.15.100.1
-> Destination Port - TCP 80
-> Action - Allow

Principle -> traffic not explicitly permitted is denied -> default deny / implicit deny

Next Generation Firewalls (NGFW)

Incorporate contextual information -> user identity -> application type -> time of day

Can serve as NAT gateways -> translate public IPs to private IPs

Can perform content filtering -> URL filtering, other policies

Web application firewalls -> application aware -> detect SQL injection, cross-site scripting, other web attacks

Deployment Choices

Firewall type
-> Network firewall -> physical device on network
-> Host-based firewall -> software on server

Technology
-> Open-source or proprietary
-> Hardware firewalls usually proprietary

Deployment mechanism
-> Dedicated hardware appliance with firmware
-> Virtual appliance on virtualization platform

Benefits of both -> minimal installation -> quickly configure rules

---

Virtual Private Networks (VPNs) and its Concentrators

Purpose

Provide secure connectivity for IT administrators

Site-to-site VPNs -> securely connect remote networks, e.g., branch offices to headquarters

Remote access VPNs -> allow mobile workers to securely connect from remote locations

How VPNs Work

Create an encrypted virtual tunnel between two systems over the internet

Traffic entering the tunnel is encrypted and decrypted at the other end

From user perspective, network functions normally but intercepted traffic appears unreadable

VPN Endpoints

Require a device on the remote network to accept connections

Can be a firewall, router, server, or dedicated VPN concentrator

High-volume VPN traffic -> dedicated VPN concentrator preferred for efficiency and high bandwidth

Firewalls, routers, and servers -> can serve as VPN endpoints but may suffer performance issues due to encryption overhead

VPN Protocols

IPSec -> network layer protocol, robust and secure, good for site-to-site VPNs

L2TP over IPSec -> supports data link layer traffic, secure but complex to configure

SSL/TLS VPNs -> application layer, work with any system with a web browser, use port 443, widely firewall-friendly

HTML5 VPNs -> web-based interface, proxy network resources without full internal network access

VPN Tunneling Approaches

Full Tunnel VPN -> all traffic from remote device routed through VPN -> everything encrypted, protects corporate and web traffic

Split Tunnel VPN -> only selected traffic routed through VPN -> rest goes through local network

Reduces bandwidth load but exposes some traffic to the internet

Generally discouraged because users assume all traffic is secure

Always-On VPN -> automatically connects all corporate mobile devices to VPN on power-on -> ensures all traffic is encrypted and protected

---

Network Access Control (NAC)

Purpose

Restrict network access to authorized users and devices

Ensure users only access resources appropriate to their role

How NAC Works

Intercepts network traffic from devices connecting to wired or wireless networks

Verifies system and user authorization before allowing communication

Authentication Protocol

Often uses 802.1x for access control

Components of 802.1x

Supplicant -> the device trying to connect, runs special software to handle NAC tasks

Authenticator -> switch in wired network or wireless controller in wireless network, receives credentials

Authentication Server -> centralized server that validates credentials, often via RADIUS

Authentication Flow

User attempts to join network

NAC supplicant sends credentials to authenticator

Authenticator forwards credentials to authentication server

Server sends RADIUS Accept -> device granted access

Server sends RADIUS Reject -> device denied access, user prompted to retry

Advanced NAC Features

Role-Based Access

Places users on network segments based on identity

Example -> students on student VLAN, faculty on administrative VLAN

Achieved using VLAN assignments

Posture Checking / Health Checking

Verifies device complies with security policies before granting full access

Checks include -

Antivirus running and up-to-date

Host firewall properly configured

Device has recent security patches

Failing devices -> placed in quarantine VLAN with limited access to obtain updates

After remediation, device retested and moved to proper VLAN

NAC Enforcement Methods

In-line -> NAC device directly makes and enforces access decisions

Out-of-band -> NAC device makes decisions, network devices enforce them

NAC Deployment Choices

Agent-based -> specialized software installed on device

Agentless -> external scanning of devices for insecure configuration or compromise

---

IoT and Embedded Systems

Overview

Embedded systems -> small computers integrated into everyday devices

Internet of Things (IoT) -> network-connected smart devices in homes, vehicles, workplaces

Examples -> smart TVs, smart garage doors, smart sprinklers, smart cars, wearable fitness devices, smart meters

Evolution

Began with network-connected devices like printers and game consoles

Wireless connectivity enabled easier access and new use cases

Spread from home devices to vehicles, hospitals, drones, and industrial systems

Security Challenges

Software Updates -> many smart devices have limited UI, making updates difficult, often run outdated OS

Network Exposure -> smart devices share home or office networks, a compromised device can be a gateway

Cloud Connectivity -> devices often connect to cloud services for command and control, bypassing firewall protections

Real-World Example

2015 Jeep hack by Charlie Miller and Chris Valasek

- Remote attackers took control via internet connection
- Started small -> radio, air conditioning
- Escalated -> disabled accelerator, stopping the car on highway
- Attackers were 10 miles away

Applications Beyond Home

Wearable fitness and medical monitors

Surveillance systems with audio/video and motion detection

Facility automation in hospitals, aircraft, utilities

Industrial sensors and smart meters

Embedded Device Security

Key Practices

Change weak defaults -> always change default administrative passwords, hackers know them and can compromise devices quickly

Regular updates -> ensure firmware/software is up-to-date, critical to protect both the device and the entire network

Update Methods

Automatic updates -> device downloads and installs updates without user intervention

Manual updates -> user must check manufacturer website and apply updates manually

Industrial environments -> use formal firmware version control, updates go through change control process

Security Enhancements

Security wrappers -> act as a mini-firewall for the device, vetting input/output to prevent direct attacks

Layered security -> implement multiple overlapping controls for redundancy and defense-in-depth

Real-World Example

Foscam baby monitor hack

Vulnerable device allowed remote control

Parents didn’t update firmware

Hacker accessed device and screamed through the monitor

Could have been prevented by applying the available update

Firmware Version Control

Purpose -> ensures all system components run the correct firmware versions

Implementation -> updates only via a formal change control process that -

evaluates the risk of the update

carefully manages rollout across all devices

Handling Unpatchable Vulnerabilities

Sometimes devices cannot be patched for known vulnerabilities

Solution -> use security wrappers -

device not directly accessible on the network

wrapper monitors all input/output

only allows vetted requests to reach the device

acts like a mini firewall for the embedded device

Layered Security Approach

Always use security control diversity -> multiple methods to achieve the same protection goal

Redundancy increases safety -> if one control fails, others protect the system

Layered defenses improve odds that embedded device attacks cannot compromise the network

---

Protecting Embedded Systems with Network Segmentation and Firewalls

Network Segmentation

Purpose -> isolates embedded or untrusted devices from trusted systems

How it works -

Embedded devices go on a separate network

Standard corporate devices (laptops, desktops, servers) stay on the main network

Firewall controls access between networks

Benefit -> even if a smart device is compromised, your main systems remain safe

Think of it like a DMZ -> embedded systems can access the internet or each other, but strict rules prevent them from touching trusted systems

Application Firewalls

Purpose -> protect embedded devices that have web interfaces

Protection against -> web attacks such as -

SQL injection

Buffer overflows

Cross-site scripting (XSS)

How it works -> monitors inbound traffic and blocks malicious requests before they reach the device

Layered Defense

Combining network segmentation + application firewalls + other controls = layered security

Effect -> multiple safeguards reduce risk and make it much harder for attackers to compromise devices or spread to the main network

---

Cloud Computing Overview

What is Cloud Computing

Delivery of computing services over a network to a remote customer

User does not manage or see the underlying infrastructure

Services are accessed through the internet or private networks

Everyday Examples

Gmail -> Google provides email as a cloud service

AWS -> Virtual servers running in Amazon data centers

Salesforce -> Customer scripts run on Salesforce cloud platform

Key Idea

Technology details are transparent to the user

Provider manages hardware software scaling and availability

NIST Definition Explained

Formal Definition Source

Defined by NIST -> National Institute of Standards and Technology

Core Characteristics from NIST

Ubiquitous and convenient access

On demand resource availability

Network based access

Shared pool of configurable resources

Minimal management effort required

Cloud Computing Characteristics

Ubiquitous Access

Resources accessible from anywhere with network access

Public clouds -> internet based

Private clouds -> restricted internal networks

On Demand Self Service

Resources created or destroyed as needed

Servers storage and services available in seconds

No provider interaction required

Resource Pooling

Infrastructure shared among multiple customers

Supports oversubscription

Enables economies of scale

Broad Resource Availability

Networks

Servers

Storage

Applications

Services

Rapid Elasticity

Resources scale up or down quickly

Appears as infinite capacity to users

Cloud Service Models

Overview

Cloud services are grouped into 3 main categories

Defined by the cloud reference architecture

Models differ by who manages what

Software as a Service SaaS

Definition

Provider delivers a complete application

Customer only uses the software

No infrastructure or platform management required

Vendor Responsibilities

Application development

Server configuration

Storage networking and infrastructure

Customer Responsibilities

User access management

Data awareness and protection

Access Method

Web browser based access

Minimal or no local configuration

Examples

Google Apps email

Microsoft Office 365

Box

Dropbox

Credit card processing services

Travel and expense management systems

Infrastructure as a Service IaaS

Definition

Vendor provides basic computing resources

Customer builds and manages their own IT environment

```
Example -> Purchasing server instances and configuring them to run your own software is an example of what cloud
deployment model
```

Vendor Responsibilities

Physical hardware

Data center security

Underlying infrastructure

Customer Responsibilities

Operating systems

Applications

Data security

System configuration

Common Resources Provided

Compute capacity

Storage

Networking

Major Providers

Amazon Web Services

Microsoft Azure

Google Compute

Platform as a Service PaaS

Definition

Vendor provides a ready to use platform

Customer runs their own application code

No server management required

Responsibility Split

Vendor manages operating system and platform

Customer manages applications and data

Positioning

Middle ground between IaaS and SaaS

Shared Responsibility Model

Core Concept

Security responsibilities are shared

Responsibility shifts depending on service model

IaaS Responsibility Split

Vendor -> hardware and data center security

Customer -> OS applications and data

PaaS Responsibility Split

Vendor -> hardware OS and platform

Customer -> applications and data

SaaS Responsibility Split

Vendor -> almost everything

Customer -> data classification and access control

Why This Matters for Security

Misunderstanding responsibility leads to security gaps

Critical concept for public cloud security

Frequently tested in exams

Cloud Deployment Models

Overview

Cloud reference architecture defines 5 deployment models

Each model delivers cloud benefits in different ways

No single model is inherently better than the others

Private Cloud

Definition

Cloud infrastructure used by one organization only

No sharing of resources with other organizations

Characteristics

High control and customization

Improved data sensitivity handling

Retains cloud benefits like scalability and agility

Ownership Models

Built and operated internally

Operated by a third party on behalf of the organization

Public Cloud

Definition

Cloud services offered to any customer

Uses a multitenancy model

Characteristics

Shared physical infrastructure

Multiple customers run workloads on the same hardware

High scalability and cost efficiency

Security Model

Follows the shared responsibility model

Customer -> data classification and access control

Provider -> infrastructure security and encryption

Hybrid Cloud

Definition

Combination of private cloud and public cloud

Use Cases

Sensitive workloads stay in private cloud

Less sensitive workloads run in public cloud

Benefits

Flexibility

Balances cost savings and security requirements

Multi-Cloud

Definition

Use of 2 or more public cloud providers

Advantages

Vendor flexibility

Ability to leverage pricing and service differences

Challenges

Increased operational complexity

More difficult security management

Community Cloud

Definition

Shared cloud used by related organizations

Not open to the general public

Characteristics

Similar to private cloud but shared within a community

Designed for common goals or requirements

Example

Universities sharing computing resources for faculty and students

Mentioned Exam Focus Points

Key Reminders

No deployment model is universally superior

Choice depends on

Cost considerations

Regulatory requirements

Data sensitivity

Operational complexity

Managed Security Services and Cloud Security Providers

Managed Service Providers MSPs

Organizations outsource technology functions to Managed Service Providers MSPs

Used for commodity tasks or services handled more efficiently by third parties

Can include critical security functions

Managed Security Service Providers (MSSPs)

Definition

Vendors that provide security services for other organizations

Act as trusted security partners

Key Points

Must be carefully monitored

Should align with organizational security objectives

Scope of Services

Full responsibility for security infrastructure

Specific services such as

Log monitoring

Firewall and network management

Identity and access management

Security as a Service (SECaaS)

Used when services resemble Software as a Service

Considered a sub-category of MSSP

Boundary between MSSP and Security as a Service is blurry

Cloud Access Security Brokers (CASBs)

Purpose

Add a third-party security layer between users and cloud services

Network-Based CASB

Sits inline between users and cloud provider

Monitors requests in real time

Can block actions such as

Sharing sensitive data with unauthorized users

API-Based CASB

Does not sit inline

Uses APIs to query cloud services

Fully cloud based

May not block actions in real time depending on design

Third Party Security Agreements

Best Practices

Develop a written agreement

Clearly define responsibilities

Include Service Level Agreements SLAs

Explicitly cover

Incident notification

Incident response procedures

Vendor Risk Management and Vendor Life Cycle

Importance of Vendors

Vendors are integral to IT operations including hardware software and cloud services

They directly affect confidentiality integrity and availability

Vendors extend the organizations technology environment

Vendors must follow security controls at least as strong as internal controls

Weak vendor security can become the weakest link

Vendor Risk in Cloud Computing

Cloud relationships often involve vendor lock in

Difficult to exit quickly if conditions become unfavorable

Requires strong due diligence

Assess financial stability to avoid vendors close to bankruptcy

---

Vendor Management Life Cycle

Vendor Selection -> Onboarding -> Monitoring -> Offboarding
Vendor Selection

Organizations may add dozens or hundreds of vendors yearly

Selection may involve

RFP -> Request for Proposal

Informal evaluation

Security teams should

Define security requirements

Participate in vendor evaluation

Assess vendors risk management controls policies and methodologies

Vendor Onboarding

Verify contract details

Establish technical arrangements for data transfer

Ensure strong encryption for

Data in transit

Data at rest

Define security incident notification procedures

Vendor Monitoring

Perform ongoing vendor assessments

Activities may include

Site visits

Regular security reviews

Reviewing independent audit reports

Handle security incidents at vendor sites

No reported incidents at all may be a red flag

Vendor Offboarding

Ensure vendor destroys all confidential data

End relationship in an orderly manner

Life cycle may restart with a new vendor

Standards Reference

ISO 27036 -> Information security for supplier relationships

Part 4 focuses on cloud service provider security

Vendor Agreements and Contracts

Purpose of Vendor Agreements

Ensure interoperability

Define expected service levels

Protect security and compliance interests

Reduce misunderstandings and disputes

Types of Vendor Agreements

Non Disclosure Agreement (NDA)

First agreement usually signed

Ensures confidentiality of shared information

Protects both organizations during early discussions

Service Level Requirements (SLR)

Define customer expectations from the vendor

May include

System response time

Service availability

Data preservation

Performance metrics

Service Level Agreement (SLA)

Formal contract based on negotiated SLRs
Example -> SLAs are used to define availability requirements for an IT service that an organization is purchasing from a vendor

Defines

Conditions of service

Penalties if service levels are not met

Memorandum of Understanding (MOU)

Informal written agreement

Used when legal disputes are unlikely

Common for internal service providers across business units

Business Partnership Agreement (BPA)

Used when organizations form a partnership

Defines

Responsibilities of each partner

Profit sharing

Example -> Joint product development and marketing

Interconnection Security Agreement (ISA)

Defines how organizations interconnect

Networks

Systems

Data

Specifies

Encryption standards

Transfer protocols

Connection security parameters

Master Service Agreement (MSA)

Umbrella agreement covering overall relationship

Used when multiple projects are expected

Saves time by avoiding repeated negotiations

Statement of Work (SOW)

Defines specific project details

Governed by the parent MSA

Includes scope timeline and deliverables

Security and Compliance in Agreements

Security Requirements

Agreements should include minimum security controls

Example

Encryption at rest and in transit

AES-256 bit encryption

Compliance and Oversight

Agreements must

Document all security requirements

Allow performance and compliance monitoring

Monitoring may be done by

Customer

Independent third party

Audit Rights

Customer should have the right to audit

Audits may include

On site visits

Document reviews

Policy and procedure assessments

Encryption Basics

Encryption is a critical security control used to protect confidentiality of data

It uses mathematical algorithms to transform readable data into an unreadable form

Only authorized users can access encrypted data

Plaintext and Ciphertext

Plaintext

Data in its normal readable form

Anyone can read it if they have access

Ciphertext

Result of encrypting plaintext

Appears as random unreadable data

Cannot be understood without decryption

Encryption Components

Encryption algorithm

Mathematical formula used to encrypt data

Encryption key

Acts like a password for the data

Must be protected carefully

If the correct key is not available

Decryption will not work

Data remains protected

Decryption Process

Uses

Decryption algorithm

Decryption key

Converts ciphertext back into plaintext

Unauthorized users without the key cannot decrypt the data

Encryption Use Cases

Data at Rest

Stored data

Includes

Individual files

Entire disks

Mobile devices

Even if stolen or accessed

Data is unreadable without the key

Data in Transit

Data moving across a network

Examples

HTTP traffic is unencrypted

HTTPS traffic is encrypted

Encryption protects against eavesdropping

Used in

Secure websites

Email communications

Mobile app traffic

Virtual Private Networks VPNs

Exam Focus Points

Encryption transforms plaintext into ciphertext

Protects

Data at rest

Data in transit

Key protection is vital

Without the key

Data remains secure and inaccessible

Encryption Algorithm Categories

Encryption algorithms are classified based on how keys are used

Two major categories

Symmetric encryption

Asymmetric encryption

Symmetric Encryption

Also called shared secret encryption

Same key is used for both encryption and decryption

Sender and receiver must both know the secret key

How It Works

One user encrypts data using a secret key

Another user decrypts the data using the same key

The key must remain confidential

Group Communication Problem

With 2 users

A single shared secret key is sufficient

With 3 users

Alice and Bob need 1 key

Alice and Charlie need 1 key

Bob and Charlie need 1 key

As the number of users increases

The number of keys required increases rapidly

Common Symmetric Algorithm

AES -> Advanced Encryption Standard

Asymmetric Encryption

Also called public key encryption

Uses 2 different but mathematically related keys

Public key

Private key

Key Pair Concept

Public key

Can be shared freely

Private key

Must be kept secret

How It Works

Sender encrypts data using the recipient’s public key

Recipient decrypts data using their private key

Keys used must belong to the same key pair

Important Exam Tip

If Bob encrypts data for Alice

Bob uses Alice’s public key

Alice decrypts using her private key

Public and private keys must match as a pair

Common Asymmetric Algorithm

RSA -> Rivest Shamir Adleman

Exam Focus Points

Symmetric encryption

Same key pair for encryption and decryption

Faster but key distribution is difficult

Asymmetric encryption

Uses public and private key pairs

Solves key sharing problem

AES is a symmetric encryption algorithm

RSA is an asymmetric encryption algorithm

Hash Functions - Core Concepts

Hash functions are essential in public key cryptography

Widely used in

Digital signatures

Digital certificates

What Is a Hash Function?

A hash function is a one-way function that transforms variable-length input into a unique, fixed-length output

---

Key Properties of Hash Functions

One-Way Function

You can hash data to get a hash value

You cannot reverse a hash to recover the original data

Knowing the hash alone should never reveal the message

Variable Input -> Fixed Output

Input can be any size

A word

A sentence

An entire book

Output length is always the same

Output size depends on the hash algorithm

Unique Output (Collision Resistance)

Different inputs should not produce the same hash

If 2 different inputs create the same hash

This is called a collision

Security is broken

How Hash Functions Fail

A hash function is considered insecure if -

It is reversible

It is not collision resistant

Collision attacks are especially dangerous because they allow attackers to -

Forge digital signatures

Forge digital certificates

Common Hash Algorithms (Exam-Relevant)

MD5

Message Digest 5

Created by Ron Rivest in 1991

Produces a 128-bit hash

Term message digest = hash

Security status

Collision resistance broken

Collisions can be created in < 1 second

Not secure

Should not be used

SHA Family (Secure Hash Algorithm)

Approved by NIST

SHA-1

Produces a 160-bit hash

Severe cryptographic weaknesses discovered

No longer secure

SHA-2

Family of algorithms

Common output sizes - 128 bits are not possible

224 bits

256 bits

384 bits

512 bits

Still widely used

Some theoretical and limited attacks exist

Currently considered secure

SHA-3

Selected by NIST in 2015

Based on the Keccak algorithm

Uses a completely different mathematical design

Key features

Output length is configurable

Still meets fixed-length requirement

Designed to avoid weaknesses of SHA-1 and SHA-2

RIPEMD

Race Integrity Primitives Evaluation Message Digest

Developed by Belgian researchers

Variants

128-bit (insecure)

160-bit (secure)

256-bit

320-bit

Notable use

RIPEMD-160 is used in Bitcoin

Avalanche Effect

Small input change -> completely different hash

Examples

Adding a single period

- Changing uppercase to lowercase

You cannot tell how much the input changed by looking at hashes

---

HMAC (Hash-Based Message Authentication Code)

Combines

Hash functions

Symmetric cryptography

Purpose

Authentication

Integrity

How It Works

Sender creates a hash using

Message

Shared secret key

Receiver recomputes hash using the same key

Matching hashes confirm

Message authenticity

Message integrity

Hash Functions and Asymmetric Cryptography

Hash functions are critical for

Digital signatures

Digital certificates

Hashes ensure

Data integrity

Signature verification

Data Life Cycle

What Is the Data Life Cycle

A model that describes how data moves through an organization

Covers data from creation to destruction

Often described as cradle to grave

Helps understand how data should be protected at each stage

Stages of the Data Life Cycle

Create -> Store -> Use -> Share -> Archive -> Destroy
Create

New data is generated

Can occur

On-premises

In the cloud

Includes changes and updates to existing data

Store

Data is placed into storage systems

Storage may be

Local storage

Cloud storage

Data is retained for later use

Use

Data is actively accessed

Users view process and modify data

Systems perform operations on data

Share

Data is made available to others

Examples

Sharing a file link with customers

Granting access permissions to employees

Controlled through access control mechanisms

Archive

Data is no longer actively used

Stored in long-term storage

Not immediately accessible

Can be restored if needed

Destroy

Data is permanently removed

Must be done securely

Prevents recovery by attackers

Secure Data Destruction

Improper destruction can allow attackers to recover sensitive data

Applies to

Electronic media

Paper records

NIST SP 800-88 Media Sanitization Methods

Clear

Overwrites data with new data

Protects against casual recovery attempts

Media can be reused

Purge

More advanced than clearing

Uses stronger techniques

May include

Cryptographic wiping

Degaussing using magnetic fields

Media may still be reusable

Destroy

Physical destruction of media

Methods include

Shredding

Pulverizing

Melting

Incinerating

Data cannot be recovered and hence this is the most secure

Media cannot be reused

Choosing a Sanitization Method

Depends on

Data Classification

Whether media will be reused

Whether media leaves the organization

NIST provides a decision flowchart of Sanitization

Widely used in industry and government

Paper Record Destruction Methods

Crosscut shredding

Cuts paper into very small pieces

Pulping

Removes ink chemically

Paper recycled into new products

Incineration

Completely destroys paper

Less environmentally friendly

Cannot be recycled

Third-Party Data Destruction

Organizations may outsource sanitization and destruction

Useful when in-house disposal is not practical

Important Points About the Life Cycle

Stages do not always occur in order

Not all data goes through every stage

Examples

Data created used in memory and destroyed without being stored

Data kept permanently in active storage

Still a valuable framework for understanding data handling

Information Classification

Purpose of Information Classification

Helps users understand security requirements for different data

Defines how data should be stored handled and accessed

Ensures consistent protection based on data importance

Classification Policies

Describe security levels of information

Define how data is assigned to a classification level

Based on

Sensitivity of the data

Criticality to the organization

Common Classification Levels

Most schemes group data into

High sensitivity

Medium sensitivity

Low sensitivity

Also distinguish between

Public information

Private information

Examples of Classification Schemes

Military

Top Secret

Secret

Confidential

Unclassified

Business Organizations

Highly Sensitive

Sensitive

Internal

Public

Why Classification Is Important

Forms the foundation for data security decisions

Determines required security controls

Example

Sensitive data requires strong encryption

Applies to data at rest and data in transit

Data Labeling

Classification should include labeling requirements

Labels apply consistent markings to data

Helps users quickly recognize sensitive information

Reduces accidental misuse or exposure

Regulatory Classification Requirements

Organizations may handle externally classified data such as

PII

Personally Identifiable Information

Data that can be traced to an individual

PHI

Protected Health Information

Medical records protected under HIPAA

PCI

Payment Card Information

Credit and debit card data

Must follow PCI DSS requirements

Secure Disposal of Classified Data

Required for all sensitive information

Applies before media is

Thrown away

Recycled

Reused

Data Remnants Risk

Deleting files is not enough

Formatting disks does not fully remove data

Residual data may still be recoverable

Secure Wiping

Uses specialized tools

Properly erases

Hard drives

Flash drives

Other storage media

Prevents future recovery of deleted data

Exam Focus Points

Classification drives handling storage and access rules

Sensitivity and criticality determine classification

PII PHI and PCI are regulator-defined data types

Secure wiping is required to prevent data residues

Security Logs & SIEM

Purpose of Security Logs

Logs are a critical resource for security professionals because they allow organizations to -

Accountability / Identity Attribution

Determine who caused an event

Could be a person, an IP address, or a geographic location

Traceability

Track all events related to a particular incident

Auditability

Provide clear, permanent documentation of actions

Challenges

Massive volume of log entries daily from -

Systems

Applications

Network devices

Other event sources

Manual review is tedious and inefficient

SIEM - Security Information & Event Management

SIEM systems solve these challenges by providing -

Centralized, Secure Log Collection

All logs are sent to a central point

Prevents unauthorized modification

Makes logs available for analysis

Artificial Intelligence & Log Correlation

AI analyzes logs to detect suspicious patterns

Correlates logs across silos (systems, network, applications)

Helps detect incidents that single administrators might miss

How SIEM Detects Suspicious Activity

Example workflow -

Intrusion Detection System (IDS) notices attack signature -> triggers SIEM event

Firewall detects suspicious inbound connection

Web server logs unusual SQL queries

Database server logs abnormal large query

Router logs unexpected large data flow

SIEM combines all pieces -> reveals a pattern of malicious activity

---

Key Benefits of SIEM

Centralized collection of logs

Correlation of events across systems and departments

Detection of complex attacks

Supports accountability, traceability, and auditability

Social Engineering

Social engineering is one of the most dangerous threats because it targets humans rather than systems. Attackers manipulate people psychologically to gain sensitive information or access

---

Why Social Engineering Works - 6 Psychological Tactics

Remember the 6 tactics with the acronym A-I-C-S-U-F -> Authority, Intimidation, Consensus, Scarcity, Urgency, Familiarity - attackers exploit these every day

Authority

People defer to perceived authority figures

Examples

Stanley Milgram experiment → subjects followed instructions to administer “shocks” due to authority of experimenter

Kevin Mitnick story → social engineer entered a casino security center and staff obeyed because of his authoritative demeanor.

Lesson - Don’t assume someone’s authority; verify identity

Intimidation

Attackers scare or pressure someone to comply

Example

Impersonating an admin assistant to force a help desk to reset an executive’s password with threats of anger or consequences

Consensus / Social Proof

People follow the crowd when unsure.

Examples

Riots or street bystander effect

Attackers exploit this by pretending “everyone is doing this” or following others’ behavior

Scarcity

Creates the illusion of limited opportunity to make people act quickly.

Examples

Pre-order rush for a new product

A fake “leftover router” offered by an attacker to install malicious equipment

Urgency

Pressure targets to act quickly before time runs out

Example

Hacker posing as a network technician claiming a “critical repair” is needed immediately to get access to a sensitive area

Familiarity / Liking

People are more likely to comply with someone they like or who flatters them

Example

Attackers build fake relationships, give compliments, or appear friendly to gain trust

---

Defense Strategy

User education is the solution

Train staff to recognize social engineering tactics

Authority

Intimidation

Consensus / social proof

Scarcity

Urgency

Familiarity / liking

Encourage verification of requests and identity before taking action

Foster a culture of healthy suspicion and verification-first mindset

---

Spam & Social Engineering Attacks

1. Spam (UCE – Unsolicited Commercial Email)

Unwanted messages sent for -

Marketing

Identity fraud

Mostly illegal under CAN-SPAM Act, but enforcement is tricky.

---

2. Phishing

Goal - Trick users into revealing sensitive info (passwords, account data).

Often part of reconnaissance for a larger attack.

Example -

Fake email warns “Email account almost full → fill form” → attacker captures credentials.

Danger - Credential reuse across sites → attacker gains access to sensitive accounts.

---

3. Spear Phishing

Highly targeted phishing for a specific small audience (e.g., employees at a small business).

Uses company jargon and names of leaders for legitimacy.

Example - Invoice scams → fake invoices sent to accounts payable.

---

4. Whaling

Target - Senior executives

Focus - Money, authority, influence

Example - Fake court documents urging executives to click links → malware or account compromise.

---

5. Pharming

Begins like phishing but redirects users to fake websites -

Typosquatting - URL looks almost like the real one

DNS poisoning - Users are automatically redirected to malicious sites

Goal - Steal credentials without user realizing it’s fake.

---

6. Vishing (Voice Phishing)

Attackers call directly → trick victims using social engineering tactics.

Examples -

Posing as help desk → ask for password

Asking to install “security software”

---

7. Smishing (SMS Phishing)

Spam & phishing over SMS / instant messaging.

Origin - AOL Instant Messenger (“SPIM”), now SMS/iMessage.

Often uses spoofing - fakes sender identity in email, phone, or SMS.

Key Takeaways

Attackers are persistent; only one victim needed for success.

Methods vary - email, web, phone, SMS.

Defense - Education and awareness are your strongest weapons.

Security Depends on People

Even one mistake—intentional or accidental—can compromise security.

Security education protects against these human-based risks.

Two Key Components

Component	Goal	Time Required	Methods
Security Training	Teach detailed security knowledge employees need to protect the organization	Requires dedicated learning time	Classroom instruction, online courses, integrated into onboarding programs, vendor courses
Security Awareness	Remind employees of lessons already learned	Minimal time commitment	Posters, videos, emails, quick reminders

---

Delivery Techniques

Classroom or online courses

Integrated training (e.g., onboarding programs)

Simulated exercises like phishing campaigns

Gamification and capture-the-flag exercises for engagement

Example Providers

Provider	Feature
SANS EndUser Security Awareness	Customizable modules covering a wide range of topics; updated content
Cofense PhishMe	Simulated phishing attacks to measure effectiveness; users redirected to training if they fail

---

Role-Based Training

Training should match job responsibilities -

Employees handling credit cards → PCI DSS requirements

HR staff → handling personally identifiable information (PII)

IT staff → implementing security controls

Frequency of Training

Initial training - on joining the organization or new responsibilities

Refresher training - annually or as needed for updates

Ongoing awareness - throughout the year via reminders

Content Review & Updates

Security teams must regularly review training content

Updates may be needed due to -

New threats in the security landscape

Changes in the organization’s business

Ensures training remains relevant and effective